



ISO/SAE 21434 기반 자동차 사이버보안 테스트 및 검증 매뉴얼

자동차 부품 제조사를 위한 TARA 지침서 Vol.2

2025. 12. 31

본 매뉴얼은 UN R155 및 국내 자동차관리법 등 관련 법규와 ISO/SAE 21434 표준을 기반으로, 자동차 부품 제조사를 위한 사이버보안 테스트 및 검증(Verification) 가이드를 제공하기 위해 작성되었습니다. 본 매뉴얼에 수록된 정보는 일반적인 안내를 목적으로 하며, 실제 적용 시 각 기업의 개별적인 상황과 요건을 고려해야 합니다. 본 매뉴얼은 UN R155 및 국내 자동차관리법 등 관련 법규와 ISO/SAE 21434 표준을 기반으로, 자동차 부품 제조사를 위한 사이버보안 테스트 및 검증(Verification) 가이드를 제공하기 위해 작성되었습니다. 본 매뉴얼에 수록된 정보는 일반적인 안내를 목적으로 하며, 실제 적용 시 각 기업의 개별적인 상황과 요건을 고려해야 합니다. KISA, KATRI, JIAT는 본 매뉴얼 내용의 사용으로 인한 어떠한 직·간접적인 손해나 분쟁에 대해 책임을 지지 않습니다. 따라서 본 매뉴얼을 활용하여 업무를 수행할 경우, 관련 분야 전문가의 조언을 구하고, 자체적인 검토 과정을 거치실 것을 권장합니다.

KISA, KATRI, JIAT는 본 매뉴얼 내용의 사용으로 인한 어떠한 직·간접적인 손해나 분쟁에 대해 책임을 지지 않습니다. 따라서 본 매뉴얼을 활용하여 업무를 수행할 경우, 관련 분야 전문가의 조언을 구하고, 자체적인 검토 과정을 거치실 것을 권장합니다.

01 사이버보안 테스트 개요

1-1 배경	04
1-2 목적	04
1-3 사이버보안 테스트 규제 및 표준 동향	05
1-3-1 자동차 사이버보안 테스트 규제 동향	05
1-3-2 자동차 사이버보안 테스트 표준(ISO/SAE 21434) 동향	06

02 사이버보안 요구사항 이해

2-1 사이버보안 위협 분석	08
2-2 사이버보안 등급 결정	09
2-3 사이버보안 등급과 사이버보안 요구사항	10
2-4 주요 OEM 사이버보안 요구사항 예시	12

03 사이버보안 테스트 방법론

3-1 사이버보안 테스트 유형	16
3-2 퍼징	16
3-2-1 CAN/UDS	17
3-2-2 ISO-TP	18
3-2-3 차량용 이더넷(Automotive Ethernet)	18
3-2-4 EV 충전 인터페이스	19
3-2-5 FlexRay, LIN 등 기타 인터페이스	19
3-2-6 블루투스, USB 등 외부 인터페이스	20
3-3 취약점 스캔	21
3-3-1 소스코드	21
3-3-2 오픈소스 라이브러리	22
3-3-3 서드파티 애플리케이션	23
3-4 침투 테스트	24
3-4-1 통신 채널과 관련된 차량 위협	24
3-4-2 업데이트 절차와 관련된 차량 위협	25
3-4-3 외부 커넥티비티 및 연결과 관련된 차량에 대한 위협	26
3-4-4 데이터 및 코드와 관련된 차량에 대한 위협	26
3-4-5 충분히 보호되지 않거나 강화되지 않은 경우 악용될 수 있는 잠재적 취약점	27

04 사이버보안 테스트 수행 가이드라인

4-1 보안 대책별 침투 테스트 항목과 수행 방법	28
4-1-1 PCB 디자인 보안	28
4-1-2 외부 장치 사용 기능 제한	30
4-1-3 반도체 부품 사이의 통신 인터페이스 보호	31
4-1-4 암호 알고리즘	32
4-1-5 개인정보 보호	32
4-1-6 시스템 중요 데이터 보호	34
4-1-7 업데이트 보안	35
4-1-8 일반 보안	38
4-1-9 Secure Unlock	39
4-1-10 Secure Access	41
4-1-11 Secure Flash	42
4-1-12 Secure Boot	43
4-1-13 Secure Storage	46
4-1-14 Run-Time Tuning Protection	49
4-1-15 Memory Protection	52
4-1-16 Secure Debug	54
4-1-17 HSM	56
4-1-18 OS Hardening	58

05 맺음말

[부록] 정보보호 관리체계(ISMS)와 사이버보안 관리체계(CSMS)

부록 1 정보보호 관리체계(ISMS)와 사이버보안 관리체계(CSMS) 배경	60
부록 2 ISMS 소개	61
부록 3 ISO/SAE 21434 소개	62
부록 4 정보보호 관리체계(ISMS)와 사이버보안 관리체계(CSMS) 비교	65
부록 5 ISMS 기반 ISO/SAE 21434 요구사항 비교	65

01 사이버보안 테스트 개요

한국인터넷진흥원

1-1 배경

자동차 산업은 자율주행과 커넥티비티 등 미래 차 기술을 기반으로 소프트웨어 정의 자동차(SDV) 형태로 빠르게 진화하고 있으며, 이에 따라 고성능 연산 장치를 탑재한 전자제어장치(ECU)의 비중이 지속적으로 증가하고 있다. 이러한 변화는 필연적으로 사이버보안 취약점과 위협의 확산 가능성을 높이고 있으며, 자동차 사이버보안에 대한 중요성 또한 더욱 부각되고 있다.

한편, 자동차 사이버보안 중요성에 대한 국제적인 공감대를 바탕으로 UNECE WP.29(국제 자동차 기준 조화 협의체)는 UN Regulation No.155(이하 UN R155)를 최초의 자동차 사이버보안 국제 기준으로 채택하였으며, 해당 기준은 2021년 1월 발효되어 2022년 7월부터 본격적으로 시행되고 있다.

국내 역시 자동차 사이버보안에 대한 국제적 논의 흐름에 발맞추어 자동차관리법에 사이버보안관리체계(CSMS) 관련 조항을 신설하였으며, 2024년 2월 공포되어 2025년 8월부터 시행되고 있다.

1-2 목적

이 가이드라인은 ECU 개발 및 공급 과정에서 부품 공급업체가 이해해야 할 사이버보안 테스트 관련 주요 절차와 범위를 제시하고, OEM 사이버보안 요구사항 및 국내외 규제 대응을 위한 전반적인 사이버보안 테스트 수행을 안내하는 것을 목적으로 한다. 본 가이드라인을 통해 확인할 수 있는 핵심 내용은 아래와 같다.

가. 자동차 사이버보안 규제(UN Regulation No.155, 자동차관리법)와 표준(ISO/SAE 21434)의 사이버보안 테스트 요구사항 파악

나. OEM의 사이버보안 사양과 사이버보안 요구사항(CSR)에 대한 이해

다. TARA와 사이버보안 테스트의 연계성 파악

- ① 대상 ECU에 내재된 위협으로부터 보호해야 할 자산 식별
- ② 위협 분석 및 위험 평가(TARA)를 통해 위험 수준을 도출하고, 위험 처리(Risk Treatment)에 따라 사이버보안 목표(CSG) 도출
- ③ 도출된 사이버보안 목표에 대한 보안 컨셉(위협 및 위험 관리 대책)을 OEM의 사이버보안 요구사항과 매핑
- ④ TARA 매핑 결과를 기반으로 사이버보안 목표를 검증할 수 있는 대상별 사이버보안 테스트 방법 이해

1-3 사이버보안 테스트 규제 및 표준 동향

1-3-1 자동차 사이버보안 테스트 규제 동향

국내외 자동차 사이버보안 테스트와 관련된 주요 규제는 다음과 같다.

	유럽	UNECE(유럽 경제연합회) Regulation No. 155 자동차 사이버보안 관리 체계(CSMS)와 Regulation No. 156 소프트웨어 업데이트 관리 체계(SUMS)가 이미 시행 중이다. 해당 규제는 2022년 7월부터 생산되는 신규 차량에 적용되었으며, 2024년 7월부터는 모든 생산 및 판매 차량을 대상으로 확대 적용되었다.
	한국	자동차관리법 제30조의9(자동차 사이버보안 관리체계 인증 등)과 제30조의10~제30조의12가 2025년 8월 14일부터 시행되었다. 자동차 사이버보안 테스트와 관련된 하위 법령은 2026년 8월 공포 후 2027년 8월부터 시행될 예정이다.

규제에서 요구하는 사이버보안 테스트 관련 주요 요구사항은 다음과 같다.

구분	지역	사이버보안 테스트 요구사항
UN Regulation No. 155	 유럽	7.3.6 차량 제조사는, 형식 승인 전에, 구현된 보안 수단의 유효성을 검증하기 위해 적절하고 충분한 테스트를 수행해야 한다. Annex. 1 Information document(제출해야 할 문서) 차량 형식 및 해당 시스템의 사이버보안을 검증하는데 사용된 테스트 및 해당 테스트 결과를 기술하는 승인할 차량 유형에 대한 문서
자동차관리법	 한국	제작사는 차량 제작 단계부터 사이버보안 관리체계(CSMS)를 구축하고, 인증을 받아야 한다. 소프트웨어 업데이트를 적용하기 전에 안전성 및 보안성 검증 절차를 수행해야 한다. 인증기관 또는 정부는 제작사에 보안 검증 관련 자료를 제출 요구할 수 있고, 기준에 부적합 시 인증 취소 또는 효력 정지를 할 수 있다.

1-3-2 자동차 사이버보안 테스트 표준(ISO/SAE 21434) 동향

ISO/SAE 21434 표준에서 사이버보안 테스트는 10.4.2절의 Integration and Verification과 11절의 Cybersecurity Validation에 기술되어 있다. 본 표준은 V-모델 개발 프로세스를 기반으로, 오른쪽 영역에 위치한 검증(Verification) 및 타당성 확인(Validation) 단계를 통해 제품 개발 이후 수행되어야 하는 사이버보안 테스트 활동을 정의한다.

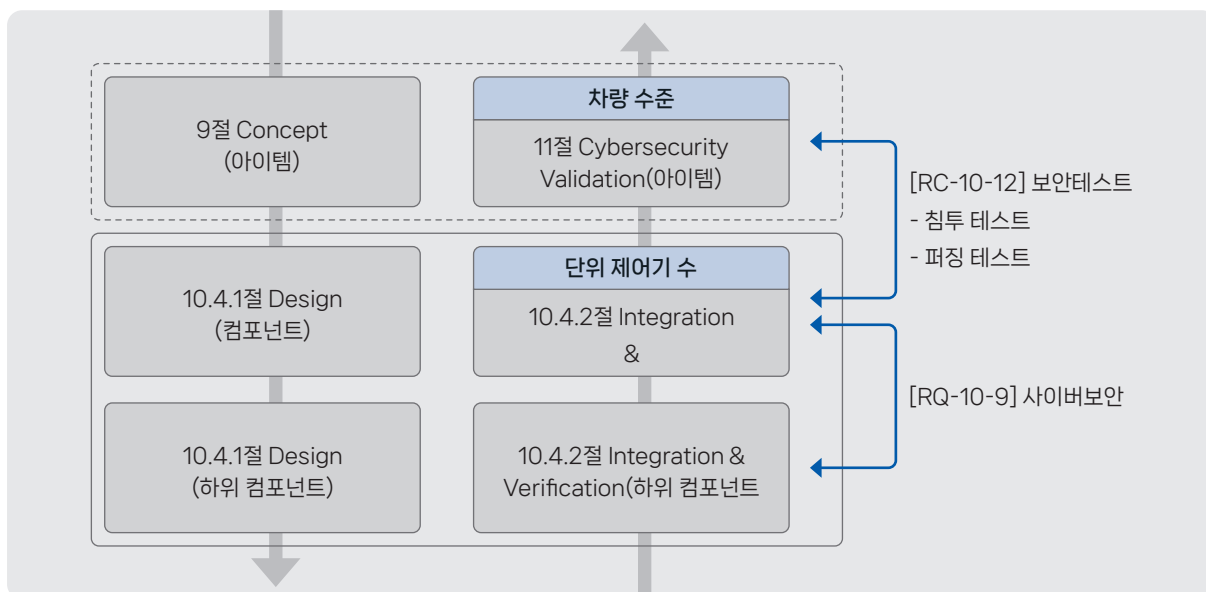


그림 01 ISO/SAE 21434 내 V모델 국문화 이미지

(출처 : ISO/SAE 21434 clause 10)

ISO/SAE 21434 표준에서는 제품 개발 과정에서의 사이버보안 요구사항 정의 및 아키텍처 설계, 그리고 개발 이후의 통합 및 검증(Integration & Verification)과 사이버보안 타당성 확인(Cybersecurity Validation) 활동을 수행하도록 규정하고 있으며, 주요 내용은 다음과 같다.

가. 9절 Concept – 사이버보안 대책

- ① ISO/SAE 21434 15절 TARA 결과로 도출된 아이템 정의, 사이버보안 목표, 사이버보안 클레임을 검토하고 이에 기반하여 사이버보안 컨셉을 정의한다.
- ② 사이버보안 컨셉은 [RQ-09-08]의 정의에 따라 사이버보안 목표를 달성하기 위해 필요한 운영상의 제어(대책) 또는 기술을 의미한다.

나. 10.4.1절 Design – 사이버보안 설계 및 구현

- ① 제품 개발 단계에서 상위 아키텍처 수준의 사이버보안 사양(Specifications)을 정의하고, 이를 구현하기 위해 적용 가능한 제어 기술을 제품 설계에 반영해야 한다.

다. 10.4.2절 Integration and Verification – 통합 및 검증

- ① [RQ-10-09]: 통합 및 검증 활동을 통해 정의된 사이버보안 사양이 충족되었는지를 확인한다.
- ② [RC-10-12]: 수행 가능한 보안 테스트 방법은 다음과 같다.
 - 기능 테스트
 - 취약점 스캔
 - 퍼징 테스트
 - 침투 테스트

라. 11절 Cybersecurity Validation – 사이버보안 검증

- ① 차량 수준에서 아이템을 대상으로 한 검증 활동으로, 실제 차량 환경과 최종 양산 구성에서 보안 상태를 평가한다.
- ② 검증 범위의 아이템은 개별 제어기에 국한되지 않고, 제어기들의 통합 시스템이나 기능 단위까지 포함될 수 있다.
- ③ [RQ-11-01]: 차량 수준에서의 검증 시 확인 사항은 다음과 같다.
 - 사이버보안 목표가 위협 시나리오 및 관련 위험에 대해 적절한지
 - 아이템이 사이버보안 목표를 달성했는지
 - 사이버보안 클레임이 유효한지
- ④ [RC-10-12]의 사이버보안 테스트 기법을 활용하여 목표 달성과 적절성을 입증한다.
- ⑤ CAL(Cybersecurity Assurance Level)을 활용하여 침투 테스트 수준과 엄격성을 결정한다.
- ⑥ 최종 산출물로 Validation Report를 작성해야 한다.

02 사이버보안 요구사항 이해

한국인터넷진흥원

2-1 사이버보안 위협 분석

OEM의 사이버보안 요구사항은 TARA(Threat Analysis and Risk Assessment)를 기반으로 도출된다. TARA 수행 과정에서 아이템의 경계와 운영 환경을 정의하고, 주요 기능과 보호 대상 자산을 식별한다. 이후 공격의 실현 가능성과 영향도를 분석하여 위험 수준을 산정하고, 이에 대한 처리(Treatment) 방안을 결정한다. 이때 위험 완화로 분류된 자산에 대해서는 구체적인 사이버보안 목표가 설정된다.

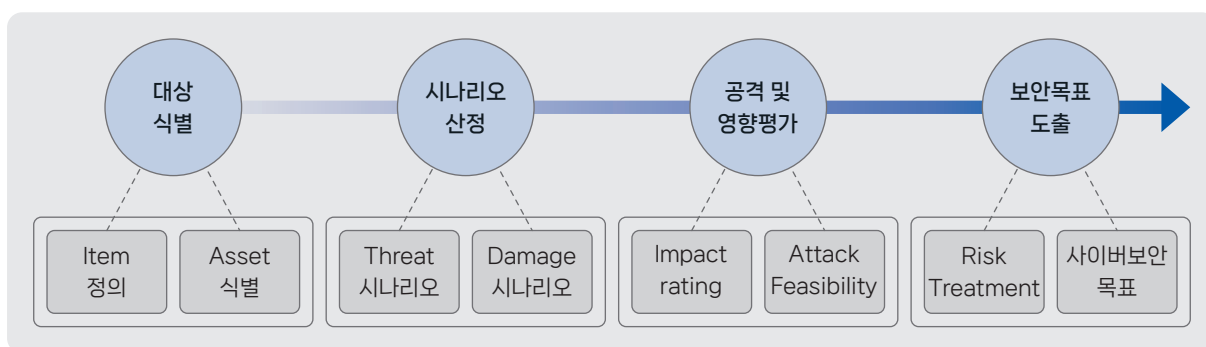


그림 02 TARA 절차

아래 그림은 일반적인 제어기 레벨의 공격 표면(Attack Surface)을 도식화한 것이다.

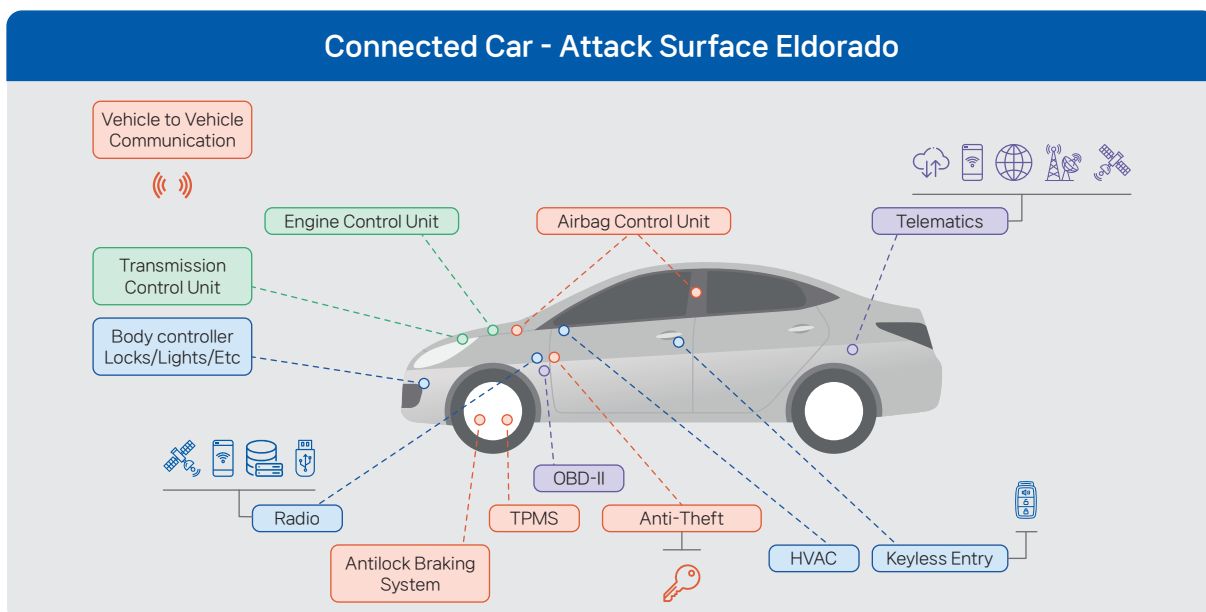


그림 03 차량 내 공격 표면 이미지

(출처: Argus)

2-2 사이버보안 등급 결정

ECU는 수행 기능에 따라 다양한 외부 접점을 가진다. 외부 접점이 많을수록 공격 경로가 많아지게 되어 사이버보안 위협에 노출될 가능성도 증가한다. ECU를 대상으로 TARA를 수행할 때는 기능 수행에 따른 외부 접점과 운영 환경을 고려하여 보호해야 할 자산을 식별하고, 이에 기반해 사이버보안 등급을 결정한다.

한편, ISO/SAE 21434 표준에서 정의하는 CAL(Cybersecurity Assurance Level) 등급은 본 가이드라인에서 사용하는 사이버보안 등급과는 다른 개념이다. CAL 등급은 사이버보안 검증 테스트의 엄격성을 결정하는 기준으로 사용되며, 세부 사항은 표준 문서를 참조해야 한다.

사이버보안 등급에 영향을 주는 제어기의 주요 기능은 다음과 같다.

- 가. 진단 기능: DTC(Diagnostic Trouble Code) 판독, 파라미터 등 설정 정보의 판독 및 수정, 강제 구동, 리셋 등 시스템 데이터 관련 기능
- 나. 소프트웨어 업데이트 기능: 제어기 펌웨어 및 애플리케이션 등 소프트웨어 업데이트 기능
- 다. 민감/보안 데이터 관리 기능: 차량 식별 정보(VIN), 사용자 인증 정보(스마트키, PIN 코드, 생체인증 등), 차량 위치 및 주행 기록, 결제 정보, 암호 키 및 인증서 저장 기능
- 라. ADAS 제어 기능: 조향, 제동, 구동 등 첨단 운전자 보조 시스템 관련 제어 기능

제어기 주요 기능에 대한 분류를 기준으로, 제어기에서 사용하는 데이터는 시스템 데이터, 민감 데이터, 보안 데이터로 구분할 수 있으며, 각 데이터는 아래와 같은 세부 항목을 보유한다.

- 가. 시스템 데이터: Calibration, Configuration 데이터, 제어기 로그 등 기밀성이 요구되지 않는 정보
- 나. 민감 데이터: 개인 식별 정보가 포함된 정보로, 외부 유출 시 사생활 침해, 법적 문제, 평판 손상 등을 초래할 수 있는 데이터
- 다. 보안 데이터: 암호 키, 인증서, 보안 로그 등 기밀성이 반드시 보장되어야 하는 정보로, 공격자가 접근 및 변조할 경우 안전, 차량 기능, 사이버보안에 직접적인 위험을 유발할 수 있는 데이터

아래 표는 사이버보안 요구사항을 정의할 때 적용 가능한 사이버보안 제어(대책)를 결정할 때 참고할 수 있는 제어기 사이버보안 등급의 예시를 정리한 것이며, OEM마다 세부적인 요구사항은 차이가 있을 수 있다.

사이버보안 등급	판단 기준
Level 1	- 양산 이후 유선 통신 인터페이스(OBD, UART/Serial, USB 등)를 통한 SW 업데이트 기능 수행 - 양산 이후 유선 통신 인터페이스를 통한 진단 기능 수행
Level 2	- 양산 이후 유선 차량 네트워크를 통한 소프트웨어 업데이트 기능 수행 - 민감 데이터 저장 기능 수행 - 양산 이후 유선 통신 인터페이스를 통한 위험 진단 기능 수행(예: 파라미터/설정 수정, 강제 구동, 리셋 등)
Level 3	- 무선 통신 인터페이스를 통한 펌웨어 업데이트(OTA) 기능 수행 - 무선 통신 인터페이스를 통한 민감 데이터 수집 기능 수행 - 보안 데이터 저장기능 수행 - 유선 차량 네트워크에 연결된 ADAS 혹은 ADAS 관련 제어 기능 수행

2-3 사이버보안 등급과 사이버보안 요구사항

OEM의 사이버보안 요구사항에 따른 보안 대책은 TARA 수행 결과로 결정된 사이버보안 등급에 따라 차등적으로 정의된다. 기능과 외부 접점이 제한적인 제어기에는 기본적인 보안 대책만 적용되지만, 게이트웨이/인포테인먼트/ADAS 시스템과 같이 기능이 복잡하고 외부 접점이 많은 제어기는 일반적인 보안 대책에 더해 HSM과 같은 하드웨어 기반의 보안 기능까지 필수적으로 요구된다. 아래표는 일반적으로 적용되는 보안 대책의 종류와 그 개요의 예시를 정리한 것이다.

보안 대책	설명	대상 자산
Common Security	PCB 디버그 포트 제거/보호	Debug Function
	외부 확장 인터페이스 제거	Security Enforcing Physical
	내부 통신 인터페이스 보호	Hardwire
	안전한 암호 알고리즘 및 키 관리	Stored Security Data
	개인정보 암호화, 시스템 중요 데이터 무결성 보장	Personal Identifiable Information
	안전한 업데이트	Firmware
	불필요 서비스 및 코드 제거	Vehicle Management Data
	외부 입력 값 검증	Vehicle Function
Secure Unlock	게이트웨이 기반의 진단 서비스 접근 제어	Diagnostic Message
Secure Access	인가된 사용자 및 장비에 대해서만 서비스 실행 허용	Diagnostic Message
Secure Flash	펌웨어 리프로그래밍 시 무결성 및 신뢰성 보장	Diagnostic Message
Secure Application	Secure Boot: 부트로더 무결성 검증	Bootloader
	Secure Storage: 중요 데이터 안전 저장	Stored Security Data
	Run-Time Tuning Protection: 런타임 무결성 검증	ECU Dynamic Variable
	Secure Debug: 인증 기반의 제한적 디버그 허용	Debug Function
	Memory Protection: 메모리 접근 권한 관리	ECU Dynamic Variable

HSM	암호 키 관리	Security Enforcing Technical
	암호 연산	
	안전한 난수 생성	
	디버그 인터페이스 제어	
OS Hardening	리눅스 기반 ECU의 OS 보안 설정 강화	OS Function

앞서 설명한 보안 대책은 TARA 수행 결과로 정의된 사이버보안 등급에 따라 제어기에 차등 적용되며, 사이버 보안 등급은 다음과 같은 특성을 기준으로 구분된다.

가. 내부 통신 인터페이스(CAN, Automotive Ethernet 등)를 통해 리프로그래밍이 가능한 제어기

나. 차량의 핵심 기능을 수행하거나 중요 데이터를 저장하는 제어기

다. 외부 통신 인터페이스(Wi-Fi, Bluetooth, BLE, LTE, SD 카드 등)를 보유한 제어기

등급별로 적용되는 보안 대책의 세부 목록의 예시는 아래 표와 같다.

사이버보안 등급	적용되는 보안 대책
1	Common Security, Secure Access, Secure Flash
2	Common Security, Secure Access, Secure Flash, Secure Application
3	Common Security, Secure Unlock ¹ , Secure Access, Secure Flash, Secure Application, HSM, OS Hardening

각 사이버보안 등급 별 보안 대책의 적용 배경은 다음과 같다.

가. 사이버보안 등급 1의 경우 디버그, 통신, 저장 데이터, 진단 기능과 같은 기본적인 자산 보호에 초점을 맞추어 최소 보안 수준을 요구한다.

나. 사이버보안 등급 2의 경우 운영중인 소프트웨어 자산까지 보호 범위를 확장하여 무결성 및 런타임 보호를 필요로 하는 제어기에 적용된다.

다. 사이버보안 등급 3의 경우 게이트웨이, 고성능 제어기, 클라우드 연계 등의 기능을 제공하는 고위험 자산을 대상으로 하드웨어 보안 모듈, 네트워크 기능 전체, 운영체제 수준까지 보안 대책의 범위를 확장하여 적용한다.

¹ 해당 보안 대책은 OBD 포트를 통한 접근에 관련된 보안 대책이므로 게이트웨이에만 해당됨

2-4 주요 OEM 사이버보안 요구사항 예시

OEM은 ISO/SAE 21434, UN R155 등 국제 표준과 규제를 기반으로 자사 위험 모델과 보안 정책을 반영하여 보안 대책 관련 사이버보안 요구사항을 정의한다. 각 보안 대책은 ECU의 기능, 외부 인터페이스 보유 여부, 안전 및 개인정보와의 연계 수준 등에 따라 차등적으로 적용된다. OEM별 세부 요구 사항에는 차이가 있으나, 일반적으로 OEM의 보안 대책별 사이버보안 요구사항 예시는 다음과 같다.

보안 대책	주요 OEM 요구사항 예시
PCB 디자인 보안	가. 양산 시 모든 디버그 인터페이스(UART, JTAG, SWD 등)은 하드웨어 또는 소프트웨어적으로 제거되어야 한다. 반드시 필요한 기능이라면 Secure Debug를 적용하여야 한다. 나. 양산 시 Flash/RAM은 BGA Type을 사용하거나 에폭시 및 본딩 처리를 하여 프로빙이 및 물리적 변조가 불가하도록 설계하여야 한다. 다. 양산 시 주요 컴포넌트에 대한 실크 표식은 제거하여야 한다.
외부 장치 사용 기능 제한	가. 기본 PCB 보드 외 확장 보드 연결을 위한 인터페이스는 제거되어야 한다.
반도체 부품 사이의 통신 인터페이스 보호	가. Main Chipset과 Flash/RAM 사이의 간격을 최소화하여 설계해야 한다. 나. PCB는 가능한 Multi-Layer를 사용하여야 한다. 다. 미사용 통신 라인(SPI, I2C, UART)은 모두 제거되어야 한다. 라. 제거가 불가능한 통신 라인은 적절한 형태의 접근 제어와 더불어 물리적 공격으로부터 보호되어야 한다.
암호 알고리즘	가. 취약하거나 비표준 암호 알고리즘을 사용하지 않아야 한다. 나. 모든 암호키는 암호화 또는 난독화 된 형태로 SHE, HSM, TEE와 같은 안전한 저장소에 저장되어 외부로 추출되지 않아야 한다. 다. 난수 생성과 관련된 토큰(Nonce) 값은 재사용되지 않아야 하며, 이를 통해 생성된 난수는 예측할 수 없어야 한다. 라. 안전한 암호 키 길이를 준수해야 한다.
개인정보 보호	가. 개인정보 저장, 관리, 처리 시 개인정보보호 원칙을 준수해야 한다. 나. 개인정보로 분류되는 데이터는 암호화 또는 난독화 된 형태로 저장해야 한다. 다. 외부 장비를 이용하여 데이터를 추출할 경우, 해당 개인정보는 암호화된 채로 추출되어야 한다. 라. 개인정보 또는 민감정보를 저장하는 ECU는 이러한 정보를 안전하게 파기할 수 있는 로직을 구현하여야 한다.
시스템 중요 데이터 보호	가. 시스템 관련 중요 데이터(차량 주요 기능의 설정 값 등), 보안 관련 로그에 대한 무결성을 보장하여야 한다. 나. 로그에 중요 정보가 노출되지 않아야 한다.
업데이트 보안	가. 펌웨어 다운그레이드를 허용하지 않아야 한다. 나. 양산 이후에도 보안 모듈 또는 보안 라이브러리는 안전한 업데이트 기능을 제공해야 한다.

일반 보안	가. 미사용 서비스 포트 및 입출력 드라이버는 제거해야 한다. 나. 양산 시, 개발용 편의 코드는 모두 제거되어야 한다. 다. 양산 시, 외부 통신 인터페이스를 이용한 부트로더 사용은 금지되어야 한다. 라. 오픈소스를 사용하는 경우, 알려진 보안 취약점은 반드시 보안 패치해야 한다. 마. 보안 관련 설정 변경사항 및 이벤트에 대해 로그를 남겨야 한다. 바. 리셋 또는 복구 후에도 이전에 설정된 보안설정 및 정책사항은 그대로 유지되어야 한다. 사. 외부 통신 인터페이스를 통해 수신한 데이터 혹은 코드는 사용 전에 항상 검증해야 한다. 아. 제거기가 인증서를 활용할 경우, 인증서 검증 원칙을 준수해야 한다. 자. 캘리브레이션용 통신은 양산 이후, 모니터링 기능만 허용한다.
Secure Unlock	가. 양산용 게이트웨이는 차량 네트워크를 보호하기 위해 OBD 포트에 연결되는 외부 네트워크와 차량 네트워크를 분리해야 한다. 나. 차량 외부 네트워크와 내부 네트워크 간 송/수신되는 모든 메시지들은 게이트웨이의 화이트리스트 기반 라우팅 규칙에 의해 통제되어야 한다. 다. 게이트웨이는 Secure Unlock를 통과한 진단장비로부터 수신되는 서비스에 대해서만 내부 제거기로의 진단 통신을 허용한다. 라. 게이트웨이는 OEM 사이버보안 인프라로부터 발급받은 인증서 검증용 공개키를 항상 저장하고 있다. 마. 게이트웨이의 화이트리스트 기반 라우팅 규칙의 보안 수준은 진단장비에 발급된 인증서의 권한에 따라 보안 통제되어야 한다. 바. 진단장비는 사용 권한에 맞는 인증서를 OEM 인프라로부터 발급받아 설치해야 한다. 사. 진단장비는 OEM 인증서 설치를 위한 안전한 실행 환경을 확보하여야 한다. 아. 만약 진단장비가 발급받은 인증서가 유효하지 않은 경우, OEM 인프라로부터 인증서를 재발급 받아야 한다.
Secure Access	가. 진단 서비스 중 제거기 동작에 영향을 주는 위험 기능들에 대해, 양산용 제거기는 인가된 사용자 및 진단 장비에 의해서만 동작되도록 통제되어야 한다. 나. Secure Access는 OEM에서 제공하는 은닉 알고리즘 기반의 사용자 인증 보안 라이브러리를 적용하여 구현하여야 한다. 다. Secure Access는 단품 수준에 적용되는 기능으로 Secure Unlock를 통해 1차 보안 통제를 구현하고 Secure Access를 통해 2차 보안 통제가 적용되어야 한다. 라. 진단 서비스 중 제거기 동작에 영향을 주는 위험 기능들에 대한 상세 내용은 OEM 표준 사양서에 정의된다. 마. 협력사는 OEM 인프라로부터 OEM 전용 알고리즘 기반 사용자 보안 인증 라이브러리를 신청 및 배포 받아야 한다.
외부 장치 사용 기능 제한	가. 양산용 제거기의 펌웨어 업데이트는 블록 단위의 RSA 전자서명 검증 과정을 통해 수행되어야 한다. 나. 제거기 단품 수준에서 안전한 펌웨어 업데이트를 위해, 진단 서비스 관련 장치는 OEM에서 제공하는 은닉 알고리즘 기반의 사용자 인증 보안 라이브러리를 적용하여 구현해야 한다. 다. 차량 수준에서의 펌웨어 업데이트는 Secure Unlock를 통해 1차 보안 통제를 수행하고 Secure Access를 통해 2차 보안 통제를 수행하고 Secure Flash를 통해 3차 보안 통제를 적용하여야 한다. 라. 제거기 협력사는 안전한 펌웨어 업데이트를 위해 OEM 인프라에서 펌웨어 블록 단위 전자서명을 생성 및 삽입한 배포용 펌웨어를 사용해야 하며 펌웨어 블록 단위 전자서명 검증을 위해 공개키를 발급받아 제거기에 설치해야 한다.

Secure Boot	가. 부트영역 변조 검사를 위해 암호 알고리즘(메시지 인증 코드, 해시 함수 등)을 사용하여 무결성을 검증해야 한다. 나. 제어기 생산공정 단계에서 Secure Boot 기능 활성화를 위한 통신 기반 서비스를 제공해야 한다. 다. 최초 활성화 과정에서 부트 영역 검증을 위한 정보(메시지 인증 코드, 해시, 암호 키 등)가 생성되어 안전한 저장소에 저장되어야 한다. 라. 부트영역 업데이트가 정상적으로 수행되는 경우, 부트 영역 검증을 위한 정보도 함께 업데이트되어야 한다. 마. 부트영역 검증을 위해 암호 키 기반 알고리즘을 사용하는 경우, 부트영역 업데이트 시마다 검증을 위한 암호키도 함께 신규 생성되어야 한다. 6) Secure Boot 결과 및 실패 로그를 확인할 수 있는 기능을 제공해야 한다. 바. 부트영역 업데이트 과정에 Fail-Safe 기능이 적용되는 경우, 백업용 부트영역 기반 복구모드로 부팅 시에도 Secure Boot 기능이 정상적으로 동작되어야 한다. 사. 상기 언급된 안전한 저장소는 Secure Storage 요구사항을 만족해야 한다.
Secure Storage	가. 보안 영역에 대한 읽기, 쓰기, 삭제, 실행 등 접근 권한은 안전하게 통제되어야 한다. 나. 보안 영역은 평문 형태가 아닌 암호화된 형태로 저장되어야 한다. 다. 보안 영역에 저장된 중요 데이터를 사용하기 전 무결성 검증을 수행해야 한다. 라. 보안 영역에 저장된 암호키는 사용 용도별 권한을 세분화해야 하며, 특정 암호키는 오직 하나의 용도로만 사용되어야 한다. 마. 보안영역에 저장된 암호 키 등 CSP(Critical Security Parameter)는 사용 후 비 보안 영역에서 초기화 삭제되어야 한다.
Secure Debug	가. 생산 출시 이후에는 기본적으로 Secure Debug 기능 활성화를 통해 디버깅 인터페이스를 안전하게 통제해야 한다. 나. 활성화된 Secure Debug 기능을 임시 해제할 수 있는 안전한 수단을 기술적/관리적 측면에서 모두 제공해야 한다. 다. Chip에서 패스워드 기반 Secure Debug 기능 제공 시, 가급적 모든 제어기마다 서로 다른 패스워드를 적용할 것을 권장한다. 라. Chip마다 Secure Debug 기능을 제공하는 방식이 상이하므로, Chip에 맞는 Secure Debug 컨셉을 OEM 사이버보안 담당자와 협의를 통해 진행한다.
Run-Time Tuning Protection	가. 부트 영역 포함 다른 중요 펌웨어 영역들까지 무결성 검증 대상이며, 기본적으로 Secure Boot 요구사항을 모두 준수해야 한다. 나. RTP는 부트영역에 대한 Secure Boot 검증이 완료된 이후, 런타임 시 중요 펌웨어 영역 전체를 대상으로 무결성 검증을 순환적으로 반복하여 수행해야 한다. 다. 특정 펌웨어 영역에 대한 무결성 검증 실패 탐지 시, 실패 로그는 최초 1회만 Secure Storage에 저장되어야 한다. 라. RTP 기능으로 인해 기존 다른 기능들의 동작성에 어떠한 영향을 주어서는 안된다. 마. 펌웨어 리프로그래밍 관련 인증이 정상적으로 완료된 상태에서만 RTP 기능이 일시적으로 해제될 수 있다.
Memory Protection	가. 생산 출시된 제어기는 비휘발성 메모리 영역에 대한 쓰기, 삭제 금지 기능을 적용해야 한다. 나. 생산 출시된 제어기는 휘발성 메모리 영역에 대한 실행 금지 기능을 적용해야 한다. 다. 생산 출시된 제어기는 코드 및 데이터 영역에 대한 읽기 금지 기능을 적용해야 한다.

HSM	가. HSM은 외장형 타입과 MCU에 통합된 내장형 타입이 존재하며 물리적인 공격에 대비하기 위해 MCU 내부에 통합된 On-Chip 형태의 타입을 권장한다. 나. Host 코어와 HSM간 통신 채널은 MCU 외부로 노출되어서는 안된다. 다. HSM에는 높은 수준의 엔트로피를 보장할 수 있는 하드웨어 기반의 난수 생성 기능을 제공해야 한다. 라. HSM은 수준에 따라 HW 기반 암호 알고리즘 가속화 모듈을 제공해야 한다. 마. Host 코어와 HSM 사이는 물리적 또는 논리적으로 분리되어야 하며, Host 코어에서는 HSM 메모리 영역에 접근 불가하고 HSM 코어는 Host 메모리 영역과 HSM메모리 영역에 접근할 수 있어야 한다. 바. HSM은 OSEK/VDX RTOS 기반 스케줄링 방식으로 구현되어야 하며, 어떠한 환경에서도 안정적인 동작을 보장해야 한다. 사. 리소스가 한정적인 임베디드 환경을 효율적으로 사용할 수 있도록, 우선 순위 기반 스케줄링 기능을 제공해야 한다. 아. HSM은 Multi-Session, Sync/Async Processing, Preemptive Scheduling, Streaming API, Fail-Safe 기능을 지원해야 한다.
OS Hardening	가. 리눅스 운영체제가 탑재된 고성능 제어기에 적용되어야 할 계정, 파일 및 디렉토리, 서비스, 로그, 네트워크 관리, 보안 기능 등의 취약점 분석 및 평가 항목을 충족하여야 한다.

비교 표에서 확인할 수 있듯이, 대부분의 OEM들은 유사한 사이버보안 요구사항과 보안 대책을 보유하고 있다. OEM의 사이버보안 요구사항은 해당 보안 대책의 적용을 전제로 하기 때문에, 사이버보안 테스트의 목적은 각 보안 대책이 올바르게 구현 및 적용되었는지를 검증하는 데 있다.

03 사이버보안 테스트 방법론

한국인터넷진흥원

3-1 사이버보안 테스트 유형

OEM이 정의한 사이버보안 요구사항에 따라 수립된 보안 대책의 유효성을 검증하기 위해, 본 활동은 ISO/SAE 21434의 검증 원칙을 기반으로 퍼징(Fuzzing), 취약점 스캔(Vulnerability Scan), 침투 테스트(Penetration Test)를 병행하여 수행한다.

가. 퍼징(Fuzzing): 입력 검증 및 예외처리 취약점을 탐지하여 시스템의 견고성을 평가

나. 취약점 스캔(Vulnerability Scan): 알려진 보안 취약점(CVE)과 설정오류를 탐지하고, 취약점 심각도(CVSS)와 해당 자산의 중요도를 고려하여 처리 우선순위를 산정

다. 침투 테스트(Penetration Test): TARA에서 도출된 위협 시나리오를 기반으로 실제 공격 관점에서 보안 대책의 실효성을 평가

이 세 가지 방법은 상호보완적으로 적용되며, 설계된 보안 대책이 실제 운영 환경에서 적절하게 구현 및 유지되는지를 입증하는 것을 목표로 한다.

또한, 사이버보안 테스트는 제어기에 적용된 보안 대책을 검증하는 것에 목적을 두고 있으므로, TARA 수행 과정에서 정의된 사이버보안 등급에 따라 수행되는 테스트 유형이 달라진다. 아래의 표는 등급별 적용되는 테스트 유형을 정리한 것이다.

사이버보안 등급	사이버보안 테스트 유형
Level 1	퍼징, 침투 테스트
Level 2	퍼징, 침투 테스트
Level 3	퍼징, 취약점 스캔, 침투 테스트

3-2 퍼징

퍼징은 차량 시스템에 정상적이지 않거나 예상치 못한 입력 값을 자동으로 생성 및 주입하고, 시스템의 반응을 관찰하여 취약점 및 오류 발생 가능성을 탐지하는 보안 테스트 기법이다. 기능 시험만으로는 발견하기 어려운 입력 값 검증 미비, 예외 처리 실패, 시스템 충돌, 서비스 거부(DoS) 등의 문제를 식별하는 것이 주요 목적이다.

차량 제어기는 실시간으로 동작하며 입력 메시지에 따라 기능이 직접 제어되는 경우가 많으므로, 예상치 못한 입력에 대한 안정성 및 견고성 검증이 필수적이다. 이에 따라 퍼징 테스트는 CAN, UDS 등 차량 내부 네트워크 뿐만 아니라 차량용 이더넷, 무선 및 외부 인터페이스(OTA, 충전 통신 등)를 포함한 다양한 경로를 대상으로 수행한다.

원활한 퍼징 수행을 위해 Synopsys Defensics, AFL++, Vector CANoe/CAPL 등 상용 및 오픈소스 도구를 활용할 수 있다.

차량 제어기에서 수행되는 퍼징 테스트 대상 예시는 다음과 같다.

3-2-1 CAN/UDS

차량 내부 네트워크에서 널리 사용되는 CAN과 UDS(Unified Diagnostic Services)는 퍼징의 주요 대상이다. 퍼징을 통해 비정상 입력에 대해 적절한 NRC(Negative Response Code) 반환 또는 진단 서비스 요청 거부가 이루어지는지 확인한다. 대표적인 퍼징 테스트 항목은 다음과 같다.

가. 비정상 길이의 CAN 프레임 전송

나. 허용 범위를 벗어난 데이터 값을 포함한 CAN 메시지 전송

다. 허용되지 않은 Service ID와 Sub-Function 조합의 UDS 요청 전송

라. 허용되지 않은 진단 세션에서의 UDS 서비스 요청 전송

마. 인증(또는 권한) 미완료 상태에서의 민감 서비스(예: 리프로그래밍, 설정 값 변경) 요청 전송

바. 비정상적 시퀀스 또는 반복 메시지 전송을 통한 서비스 거부(DoS) 유발 시나리오 검증

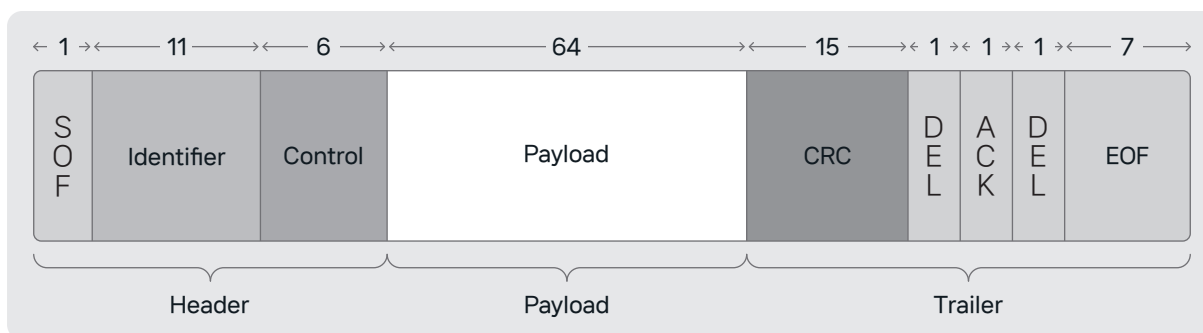


그림 04 CAN 데이터 프레임워크

(출처: Standard CAN frame format)

3-2-2 ISO-TP

CAN 상위 계층에서 동작하는 ISO-TP(ISO 15765-2)는 차량 내부 네트워크에서 대용량 메시지를 분할 전송하기 위해 사용된다. 퍼징 시에는 비정상 입력에 대해 세션이 정상적으로 종료되거나 적절한 오류가 반환되는지 확인한다. 주요 테스트 항목은 다음과 같다.

가. 비정상 길이의 First Frame(FF) 및 Consecutive Frame(CF) 전송

나. 비정상 형식 또는 값의 Flow Control(FC) 프레임 전송

다. 연속 프레임의 잘못된 시퀀스 번호 전송

라. 손상된 프레임(예: 체크섬 위조) 또는 중복 프레임 전송을 통한 서비스 거부(DoS) 유발 시나리오 검증

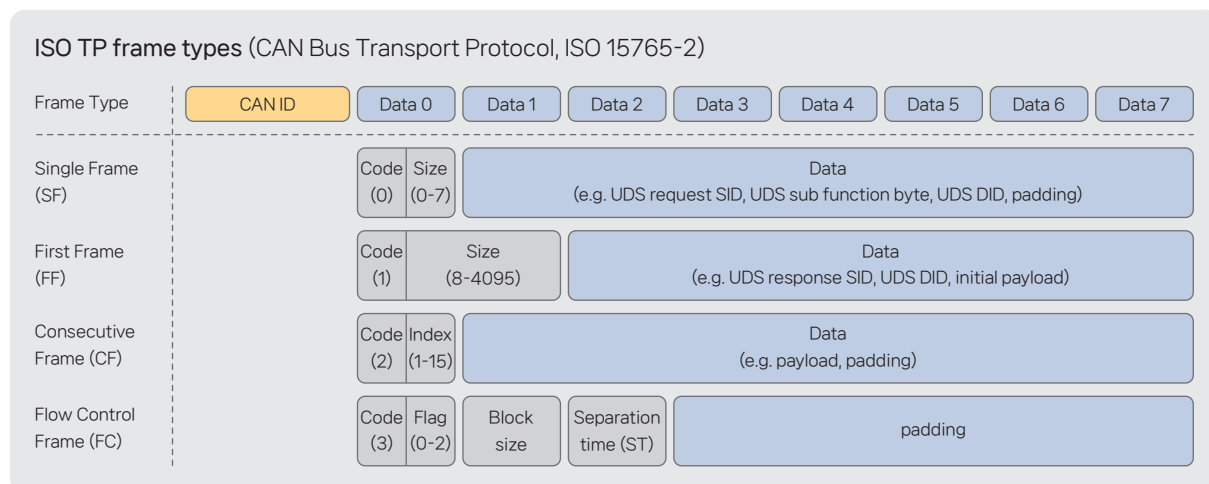


그림 05 ISO Transfer protocol

(출처: ISO 15765-2, ISO-TP)

3-2-3 차량용 이더넷(Automotive Ethernet)

차량용 이더넷 환경에서는 비정상적인 이더넷 프레임과 상위 계층 프로토콜인 SOME/IP 및 DoIP를 대상으로 퍼징을 수행하여, 비정상 입력에 대해 세션이 정상적으로 종료되거나 오류가 반환되는지 확인한다. 주요 테스트 항목은 다음과 같다.

가. 비정상적 필드를 포함한 이더넷 프레임 전송

나. 비정상적인 Request ID, TTL, Length 값을 가진 SOME/IP 메시지 전송

다. 페이로드 길이 불일치 등의 비정상적인 DoIP 메시지 전송

라. Flooding 또는 다중 연결 시도로 인한 서비스 거부(DoS) 유발

Preamble	SFD	Ethernet frame: min. 68 bytes/max. 1522 bytes					
101010..	10101011	Destination MAC address	Source MAC address	VLAN Tag	Type	Date	CRC check sum
8 Bytes		6 Bytes	6 Bytes	4 Bytes	2 Bytes	42-1497 Bytes	4 Bytes

Table: Ethernet packet framework structure

그림 06 이더넷 패킷 프레임워크

(출처: Automotive Ethernet Beginner's Guide)

3-2-4 EV 충전 인터페이스

전기차 충전 환경에서는 ISO 15118 및 OCPP 기반 통신을 대상으로 퍼징을 수행하여 충전 서비스의 안전성을 검증한다. 주요 테스트 항목은 다음과 같다.

- 가. 만료되었거나 비정상적인 인증서를 포함한 충전 메시지 전송
- 나. 비정상적인 길이(Length) 또는 분할(Fragmentation)이 적용된 PLC(Power Line Communication) 프레임 전송
- 다. 비정상적인 매개변수 값을 포함한 충전 제어 메시지를 통한 서비스 거부 유발

3-2-5 FlexRay, LIN 등 기타 인터페이스

특수 환경에서 사용되는 FlexRay와 LIN 프로토콜을 대상으로 퍼징을 수행하여 통신의 안정성과 예외 처리 동작을 검증한다. 주요 테스트 항목은 다음과 같다.

- 가. FlexRay
 - ① 비정상적인 슬롯(Slot) 값 전송
 - ② 비정상적인 프레임 길이(Frame Length) 전송
 - ③ 손상된 또는 잘못된 CRC 전송
 - ④ 스케줄 불일치(스케줄 테이블 위조) 또는 타이밍 위반

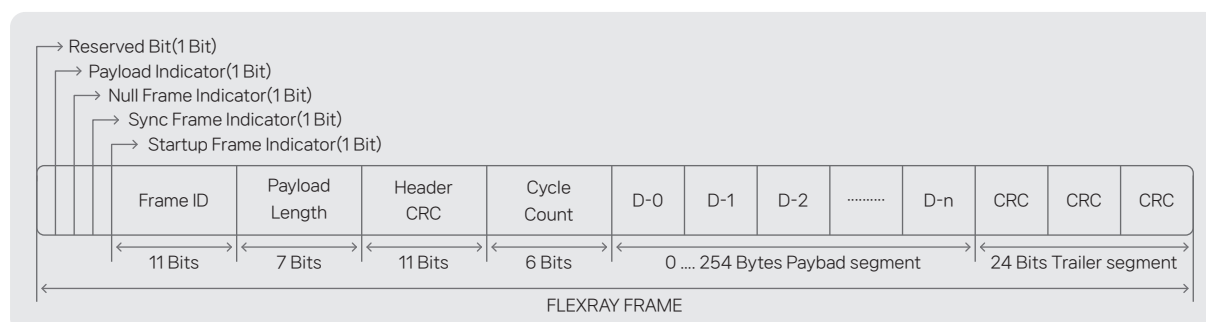


그림 07 FlexRay 프레임워크

(출처: COMPARISON OF CAN AND FLEXRAY PROTOCOL FOR AUTOMOTIVE APPLICATION)

나. LIN

- ① 스케줄 불일치(스케줄 테이블 위조) 또는 타이밍 위반
- ② 명령어 중복 삽입 또는 명령어가 누락된 메시지 전송
- ③ 체크섬 오류 또는 비정상적인 프레임 필드 전송
- ④ Break/Synch 필드 변조를 통한 통신 교란

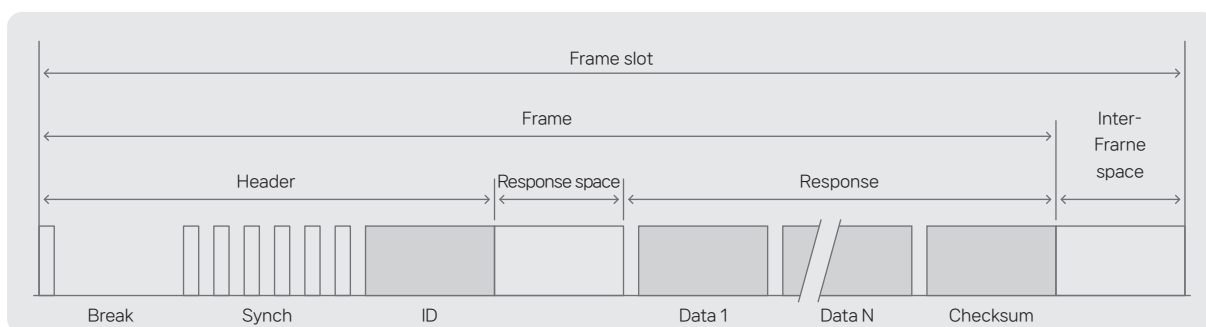


그림 08 LIN 메시지 프레임

(출처: NXP_LIN Message Frame)

3-2-6 블루투스, USB 등 외부 인터페이스

차량의 외부 인터페이스도 공격 표면(Attack Surface)에 해당하므로, 해당 인터페이스에 대해 퍼징 테스트를 수행하여 HMI 등 시스템이 비정상 입력을 적절히 처리하는지를 검증한다. 주요 테스트 항목은 다음과 같다.

- 가. 비정상적인 형식의 Bluetooth L2CAP / SDP 패킷 전송
- 나. 비정상적인 프로파일 상태를 유발하는 Bluetooth 패킷 전송
- 다. 비정상적인 USB Descriptor 정보를 가진 저장장치 연결
- 라. 손상되거나 비정상적인 헤더를 포함한 미디어 파일
- 마. 비정상적인 메타데이터를 포함한 미디어 파일

3-3 취약점 스캔

SAE J3061에서는 취약점 스캔을 자동화된 보안 도구를 활용하여 시스템 및 소프트웨어 컴포넌트에 존재할 수 있는 알려진 보안 취약점을 탐지하는 활동으로 정의한다. 이 과정에서 일반적으로 CVE(Common Vulnerabilities and Exposures), CWE(Common Weakness Enumeration) 등 공개된 취약점 데이터베이스와 대조하여 대상이 기존에 보고된 취약점에 노출되어 있는지를 확인한다.

취약점 스캔은 네트워크, 시스템, 소스코드 등 다양한 범위를 포괄하나, 차량 전장 시스템의 특수성 및 제약을 고려하여 주로 소스코드, 오픈소스 라이브러리, 서드파티(3rd-party) 애플리케이션을 대상으로 수행된다. 원활한 스캐닝을 위해 Black Duck, Javis, WhiteSource 등 상용 도구를 활용할 수 있다.

다음은 차량 전장 시스템에서의 취약점 스캔 대상 예시이다.

3-3-1 소스코드

제조사 또는 협력사가 개발한 코드에 존재하는 보안 취약점을 점검하기 위한 점검 항목은 다음과 같다.

- 가. Buffer Overflow, Double Free 등 메모리 관리 취약점
- 나. Format String Bug, Integer Overflow 등 데이터 타입 관련 오류
- 다. 메모리 누수
- 라. 외부 인터페이스로 입력되는 데이터에 대한 경계 값 및 입력 검증 부재
- 마. 암호 키, 비밀번호 등 민감 정보의 하드코딩
- 바. 소스코드에 남아 있는 디버그 메시지 또는 백도어 기능

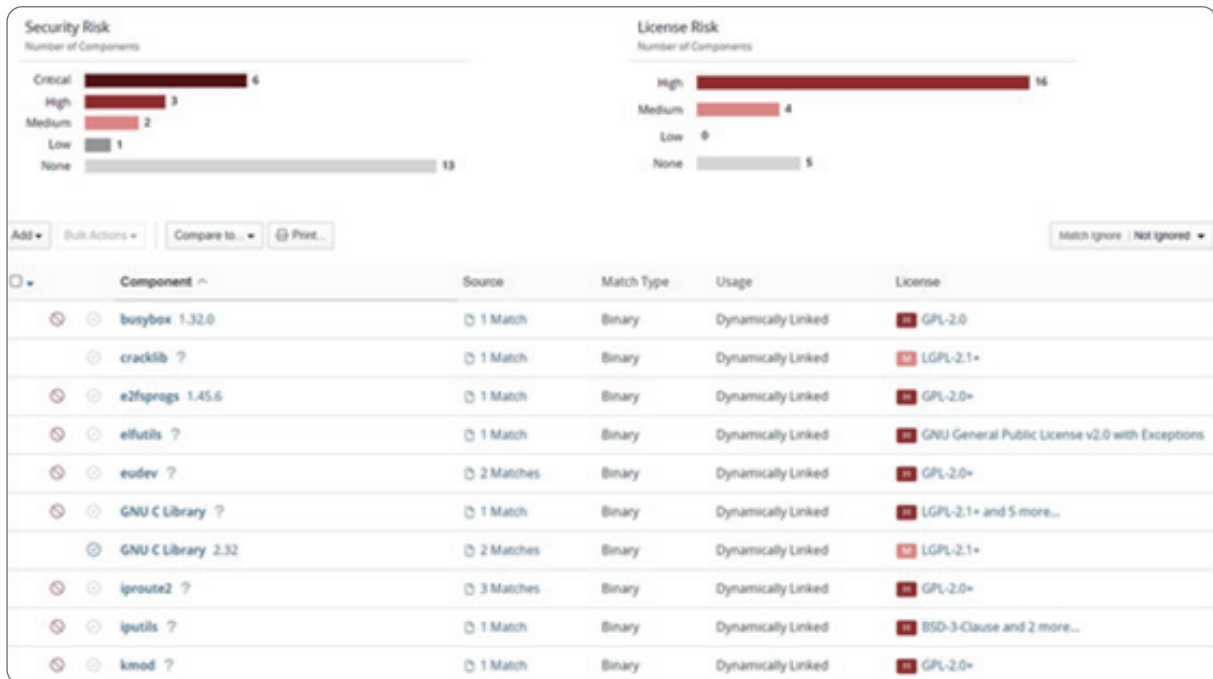


그림 09 알려진 취약점 분석 진행 예시

3-3-2 오픈소스 라이브러리

외부에서 도입한 오픈소스 라이브러리 및 프레임워크의 보안 취약점을 점검하기 위한 항목은 다음과 같다.

- 가. 사용 중인 오픈소스 버전에 대한 알려진 취약점(CVE) 확인
- 나. GPL, LGPL 등 오픈소스 라이선스 준수 여부 점검
- 다. 상호 충돌라는 라이선스 혼용 여부 확인
- 라. 개발 중단 또는 구 버전 라이브러리 사용 여부 확인
- 마. 공급망 공격 예방을 위한 라이브러리 출처 및 서명 검증
- 바. 불필요하게 포함된 오픈소스 모듈 식별 및 제거

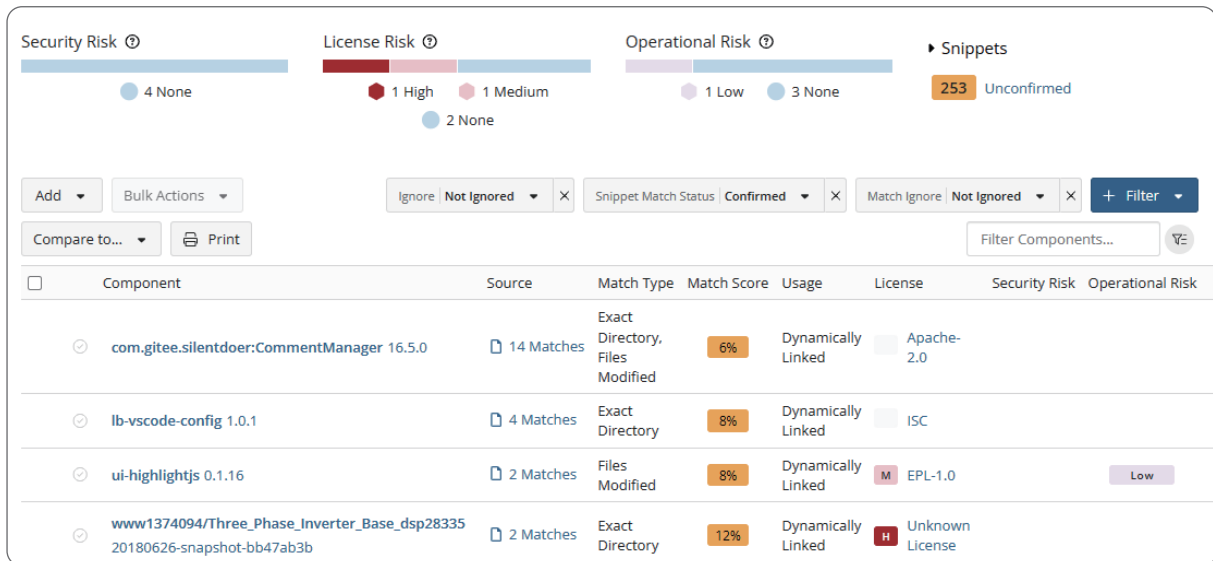


그림 10 오픈소스 식별 예시

3-3-3 서드파티 애플리케이션

외부 업체가 제공한 서드파티 애플리케이션(미들웨어, 드라이버, 서비스 모듈 등)에 대한 보안취약점 점검 항목은 다음과 같다.

- 가. 공개된 CVE 등 외부 취약점 데이터베이스에 등록된 취약점 노출 여부 확인
- 나. 보안 패치 및 최신 업데이트 적용 상태 점검
- 다. 패치 불가 항목에 대해서는 위험 완화(Risk Mitigation) 방안 검토
- 라. 레거시(구 버전) 코드 또는 유지보수 종료 코드 사용 여부 확인
- 마. 차량 시스템과의 호환성 및 상호작용(안전 영향) 검토
- 바. 불필요하게 활성화된 서비스 포트 및 디버그 인터페이스 존재 여부 확인
- 사. 기본 설정 값(디폴트 계정, 약한 강도의 비밀번호 설정 등) 점검

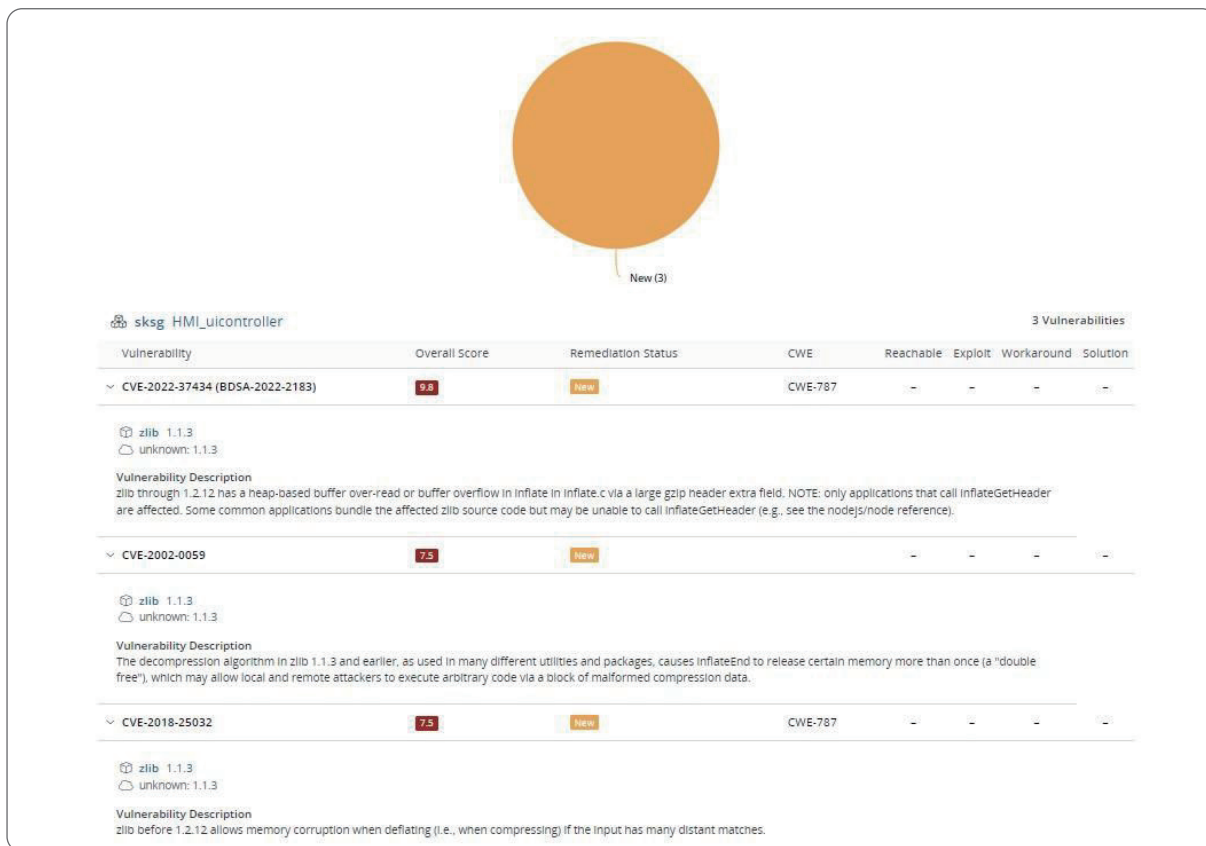


그림 11 서드파티 어플리케이션 내 취약점 점검 예시

3-4 침투 테스트

침투 테스트(Penetration Test)는 공격자 관점으로 시스템을 분석하여 보안 취약점의 존재 여부를 확인하고, 발견된 취약점의 영향 범위 및 악용 가능성을 평가하는 테스트이다. 실제 공격 시도가 포함될 수 있으므로 사전에 테스트 범위, 목표, 허용 행위, 중단 조건 및 복구 절차 등을 명확히 정의해야 하며, 제조사와 협의한 통제된 환경에서 적법한 승인을 받은 상태로 수행해야 한다. 또한, 테스트 중 발생한 결과와 증거는 보안상, 법적 관점에서 적절히 기록 및 보관하고, 테스트 후에는 영향을 받은 시스템의 정상 복구를 반드시 확인해야 한다.

본 문서의 침투 테스트 예시는 UN R155 Annex.5 Part A의 항목을 일부 선별하여 제시한다.

3-4-1 통신 채널과 관련된 차량 위협 (출처: UN R155 Annex.5 Part A 4-3-2)

UN R155 4.3.2는 차량이 외부 시스템(예: 백엔드 서버, 모바일 앱)과 정보를 주고받기 위해 사용하는 통신 인터페이스 및 프로토콜 자체가 공격 대상이 될 수 있음을 규정한다. 공격자는 이러한 채널을 통해 메시지 가로채기 및 변조, 악의적인 명령 전달 등을 시도할 수 있으며, 그 결과 차량 제어 시스템의 오동작이나 보안 설정 우회가 발생할 수 있다. 대상이 되는 주요 통신 채널은 다음과 같다.

가. 차량 내부 통신: CAN, LIN, Automotive Ethernet 등

나. 진단 프로토콜: UDS, DoIP 등

다. 물리적 인터페이스: USB, OBD-II 등

라. 차량 외부 통신: Bluetooth, Wi-Fi, V2X, 모바일 애플리케이션을 통한 통신 등

차량은 위와 같은 다양한 통신 채널을 통해 내부 시스템 및 외부 장치와 통신하므로, 해당 채널이 노출되면 메시지 변조, 정보 유출, 서비스 거부 등 심각한 위협이 발생할 수 있다. 특히, 대부분의 차량 통신은 신뢰 기반으로 설계되어 있어 메시지 인증, 무결성, 암호화가 미흡한 경우가 많으므로, 침투 테스트를 통해 취약성을 검증하는 것이 필수적이다. 통신 채널을 악용한 공격은 차량 기능과 사용자 안전에 직접적인 영향을 미치므로 철저한 검증이 요구된다.

따라서, 각 통신 채널에 대해 다음과 같은 항목들을 점검한다.

가. 인증 우회

라. 기밀성 보호 여부

나. 메시지 변조, 재전송, 시퀀스 조작

마. 자원 고갈 및 남용

다. 오류 및 예외 처리 적절성

3-4-2 업데이트 절차와 관련된 차량 위협 (출처: UN R155 Annex.5 Part A 4-3-3)

차량 소프트웨어의 OTA(Over-The-Air) 또는 물리적 업데이트 과정은 공격자가 악용할 경우 변조된 소프트웨어나 악성 코드가 주입될 수 있는 취약 지점이다. 이러한 위협은 시스템의 정상 동작을 방해하거나 차량의 핵심 기능을 변경 및 비활성화하는 결과를 초래할 수 있다. 주요 대상은 다음과 같다.

가. OTA 업데이트 서버 및 통신 경로

다. 업데이트 패키지 파일

나. USB, SD 카드 등 물리적 매체를 통한 업데이트

라. 전자서명, 암호 키 등 서명 및 인증 체계

차량 소프트웨어는 보안 패치, 기능 추가 등을 위해 주기적으로 업데이트되며, 이 과정에서의 무결성 검증, 인증 절차, 키 관리 등은 보안을 유지하는 핵심 요소이다. 그러나 업데이트 파일이 전송되거나 저장되는 과정에서 변조되거나, 암호 키가 탈취되어 무단 업데이트가 허용되는 경우, 공격자는 차량 내부 시스템을 손상시킬 수 있다. 또한, 업데이트 서버 또는 네트워크가 서비스 거부 공격을 받을 경우, 중요 보안 패치가 사용자에게 전달되지 못하는 위험 또한 존재한다. 따라서, 침투 테스트를 통해 소프트웨어 업데이트 절차가 다음과 같은 조건을 만족하는지를 검증해야 한다.

가. 업데이트 파일의 무결성 검증

다. 업데이트 수행 전/후의 상태 확인 및 롤백 기능

나. 비인가 소프트웨어 차단 및 서명 검증 로직의 안전성

라. 네트워크 및 서버에 대한 서비스 거부 대응력

3-4-3 외부 커넥티비티 및 연결과 관련된 차량에 대한 위협 (출처: UN R155 Annex.5 Part A 4-3-5)

UN R155 4.3.5 외부 커넥티비티 및 연결과 관련된 차량에 대한 위협은 차량이 외부 환경과 다양한 방식으로 연결됨에 따라, 연결 지점이 새로운 공격 표면(Attack Surface)으로 활용될 수 있는 보안 위협을 의미한다. 최근의 차량은 스마트폰, 클라우드, 백엔드 서버, V2X 인프라 등 외부 시스템과 연계되고 있으며, 이로 인해 외부에서 침입 가능성이 증가하고 있다.

해당 항목은 다음과 같은 외부 연동 지점을 주요 대상으로 한다.

가. 모바일 애플리케이션과의 연동(예: 차량 잠금 해제, 원격 시동 기능 등)

나. V2X 통신 인터페이스

라. 외부 장치와의 연결 과정에서 발생할 수 있는 취약점

다. 클라우드 기반 OTA 서버 등 외부 서비스

마. 외부 입력을 통한 정보 유출 또는 시스템 제어

외부 시스템과의 연결 지점은 차량 내부 통신과는 성격이 다르며, 인터넷 환경 및 외부 장치와의 상호작용을 포함 하므로 별도의 보안 관점에서 접근할 필요가 있다. 해당 영역은 공격자에게 노출될 가능성이 높아 취약점 공격이 집중되기 쉬우므로, 보다 정밀한 분석과 체계적인 검증이 필요하다. 따라서, 차량의 외부 연동 기능에 대해서는 침투 테스트를 통해 다음과 같은 조건을 만족하는지 검증할 필요가 있다.

가. 인증 및 권한 관리

마. 가용성 및 자원 보호

나. 세션 및 연결 보호

바. 서드파티 신뢰성

다. 입력 검증 및 예외 처리

사. 로깅

라. 기밀성 및 무결성 보호

아. 권한 최소화 및 분리

3-4-4 데이터 및 코드와 관련된 차량에 대한 위협 (출처: UN R155 Annex.5 Part A 4-3-6)

UN R155 4.3.6은 차량 내부에 저장된 소프트웨어 코드와 차량 상태, 주행 기록, 위치 정보 등 민감 데이터가 외부 공격으로 인해 유출, 변조, 삭제, 오용될 수 있는 위협을 다룬다. 공격자는 OTA 업데이트, 외부 매체(USB, SD 카드 등), 통신 채널 등을 통해 내부 저장소에 접근하거나 조작을 시도함으로써 차량 기능에 영향을 주거나 정보를 탈취할 수 있다.

해당 항목의 주요 대상은 다음과 같다.

가. 운전자 식별 정보

다. 시스템 설정 값 등 내부 데이터 오용

나. 소프트웨어 무결성

라. 민감 데이터 외부 유출

이러한 위협은 차량의 기능 안전성과 사용자 프라이버시를 동시에 위협할 수 있으므로, 저장되는 데이터와 코드에 대한 무결성, 기밀성, 접근 통제 검증이 필수적이다. 따라서, 침투 테스트를 통해 다음과 같은 항목들을 점검해야 한다.

- 가. 차량 내부 데이터의 암호화 적용 여부 및 보호 수준
- 나. 인증 없이 접근 가능한 저장소 또는 시스템 설정 영역
- 다. OTA 업데이트, UDS 프로토콜 등을 통한 코드 변경
- 라. 디버그 인터페이스 또는 외부 장치를 통한 메모리, 저장소 접근

3-4-5 충분히 보호되지 않거나 강화되지 않은 경우 악용될 수 있는 잠재적 취약점 (출처: UN R155 Annex.5 Part A 4-3-7)

UN R155 4.3.7 충분히 보호되지 않거나 강화되지 않은 경우 악용될 수 있는 잠재적 취약점은 차량 시스템에 내재된 결함 중 실제로 악용되지는 않았으나, 공격자가 이를 탐지 및 분석할 경우 공격에 악용될 수 있는 영역을 의미한다. 여기에는 설계상 보안 미비, 인증 및 접근 통제 부재, 디버그 포트, 민감 정보 하드 코딩 등 잠재적 보안 허점이 포함된다.

해당 항목의 주요 대상은 다음과 같다.

- 가. 보안 설정이 활성화되지 않은 소프트웨어 및 하드웨어
- 나. 비활성화되지 않은 디버그 인터페이스
- 다. 개발 및 테스트용 기능(백도어, 테스트 계정, 진단 기능 등)
- 라. 인증 및 권한 검증 없이 호출 가능한 API

이러한 항목들은 단순히 구현상의 결함을 넘어 설계 및 배포 과정에서 발생하는 허점들이다. 공격자는 이러한 허점들을 기반으로 초기 접근 권한을 확보하거나 권한 상승, 정보 탈취, 시스템 변조 등 후속 공격으로 연결할 수 있으므로 침투 테스트를 통해 다음과 같은 항목들을 점검해야 한다.

- 가. 배포 전 보안 설정 적용 여부
- 나. 디버그 포트 및 디버그 인터페이스 비활성화 또는 접근 통제
- 다. 개발 및 테스트용 기능
- 라. 민감 정보 노출
- 마. 인증 로직

04 사이버보안 테스트 수행 가이드라인

한국인터넷진흥원

4-1 보안 대책별 침투 테스트 항목과 수행 방법

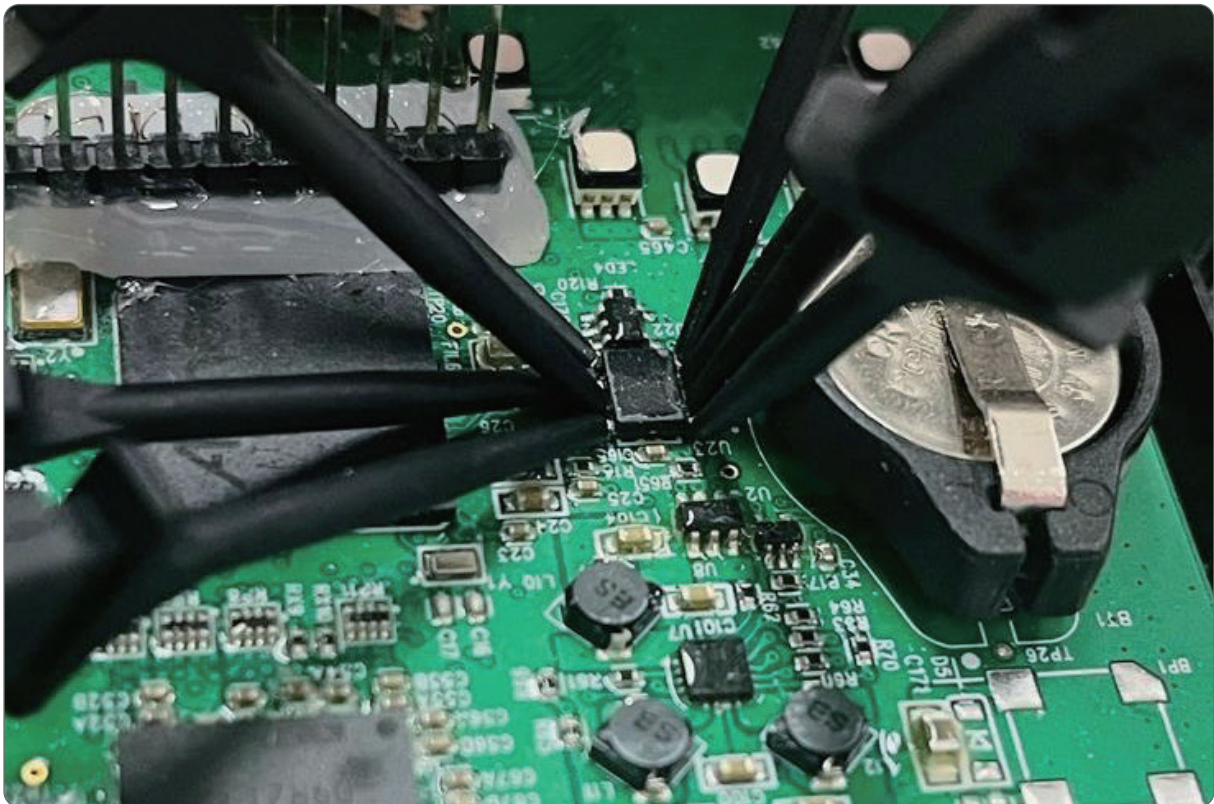
OEM이 정의한 사이버보안 요구사항에 따라 수립된 보안 대책의 유효성을 검증하기 위해 수행할 침투 테스트 항목에 대한 검토가 필요하다. 아래 자료는 각 보안 대책을 검증하기 위해 일반적으로 권장되는 침투 테스트 항목의 예시이며, 특정 OEM 요구사항 또는 규제 대응을 위해 추가 검증 항목을 필요로 할 수 있다.

4-1-1 PCB 디자인 보안

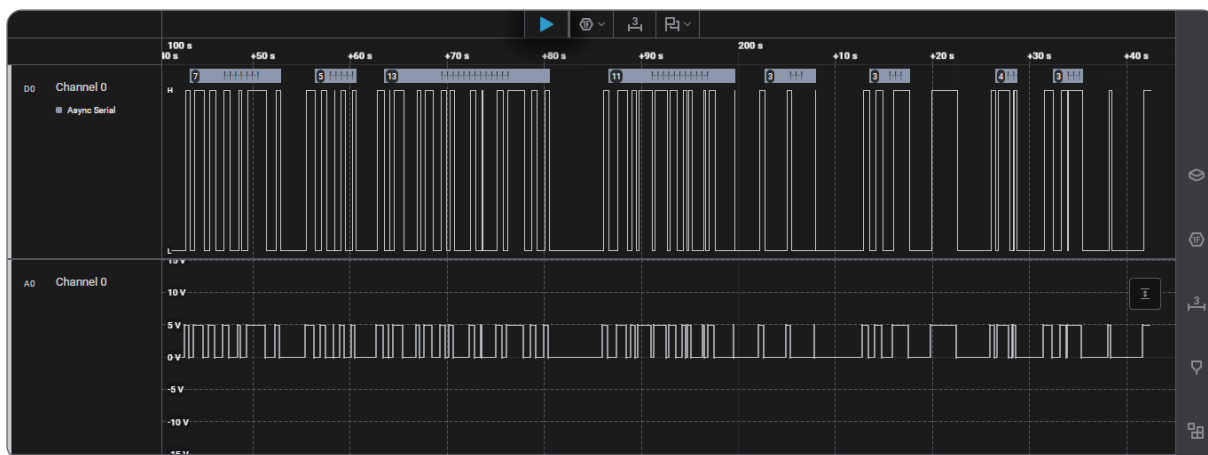
보안 대책	PCB 디자인 보안
테스트케이스 명	Probing을 통한 펌웨어 추출
UN R155 Annex5	32.1
Pre-Condition	컴포넌트 식별
필요 도구	Logic Analyzer

테스트 과정

1) PCB 상의 Flash/RAM에 탐침 장비 연결



1) PCB 상의 Flash/RAM에 탐침 장비 연결



3) 수집된 신호를 조합하여 펌웨어 추출

```

sub_4C0040                                     ; CODE XREF: sub_4C0040+8+j
        NOP
        NOP
        NOP
        NOP
        B                                     sub_4C0040
; End of function sub_4C0040

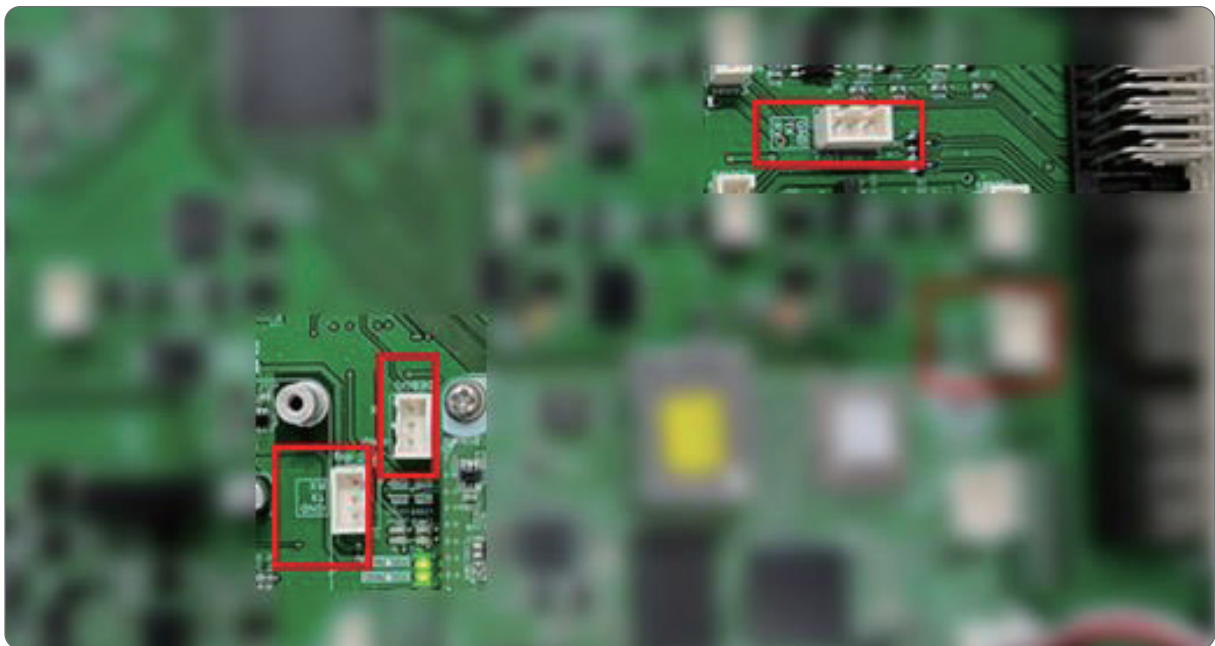
; ===== S U B R O U T I N E =====
; Attributes: noreturn

sub_4C004A
        MOVS        R0, R0
        CPSID       I
        MOV.W       R0, #0
        MOV.W       R1, #0
        MOV.W       R2, #0
        MOV.W       R3, #0
        MOV.W       R4, #0
        MOV.W       R5, #0
        MOV.W       R6, #0
        MOV.W       R7, #0
        LDR         R0, =0xED00ED00
        LDR         R1, =0x3478A400
    
```

4-1-2 외부 장치 사용 기능 제한

보안 대책	외부 장치 사용 기능 제한
테스트케이스 명	미사용 인터페이스를 이용한 확장 보드 연결
UN R155 Annex5	5.1/10.1/29.1/29.2/32.1
Pre-Condition	-
필요 도구	-
테스트 과정	

1) PCB 상의 특수 인터페이스 확인



2) 해당 인터페이스를 이용하여 소형 보드 연결 후 오동작 여부 확인

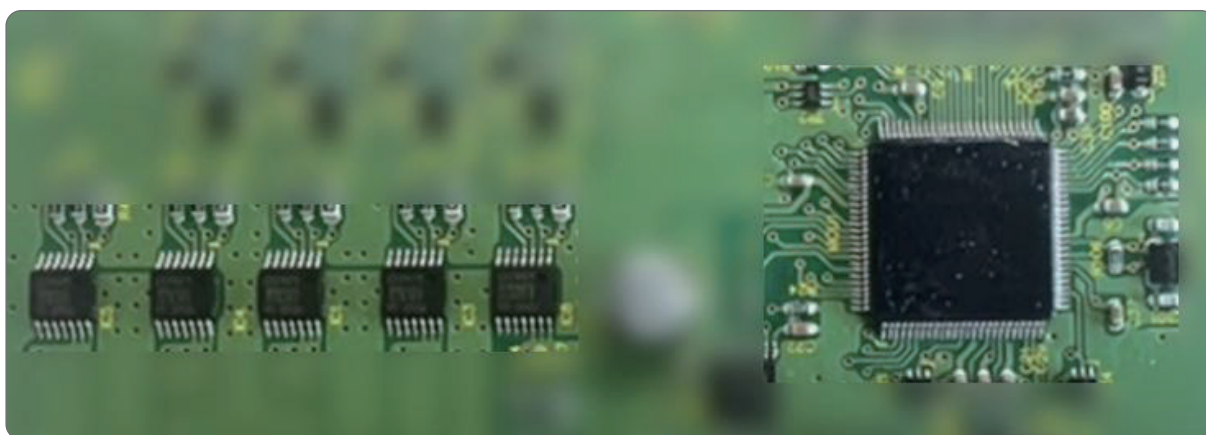


4-1-3 반도체 부품 사이의 통신 인터페이스 보호

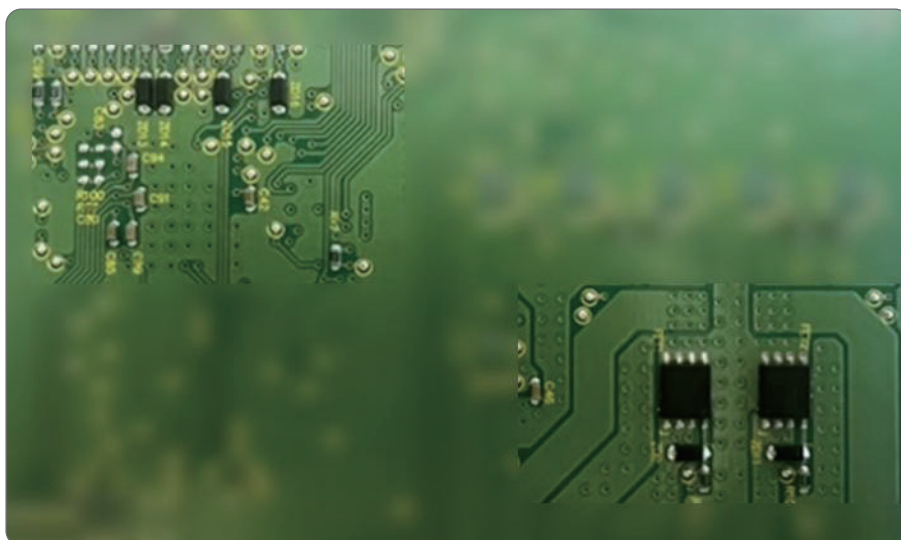
보안 대책	반도체 부품 사이의 통신 인터페이스 보호
테스트케이스 명	PCB 구조 확인
UN R155 Annex5	7.1/8.1/29.1/29.2/32.1
Pre-Condition	-
필요 도구	-

테스트 과정

1) 제어기의 하우징 제거 후 PCB 상의 불필요한 컴포넌트 확인



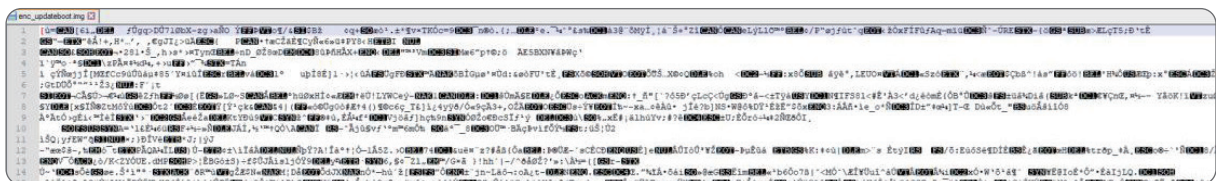
2) PCB 상의 통신 라인, 계층 구조 설계 여부 등을 확인



4-1-4 암호 알고리즘

보안 대책	암호 알고리즘
테스트케이스 명	외부로 노출된 암호 키 점검
UN R155 Annex5	19.3/26.1/26.2/26.3
Pre-Condition	-
필요 도구	-
테스트 과정	

1) 암호화가 적용된 파일 또는 펌웨어 획득



2) 접근 가능한 파일에서 암호 키 획득

```

727 function generate_aes128_encryption()
728 {
729     local FILE=$1
730     local DIR=$2
731
732     openssl aes-128-cbc -K 2b7e151628aed2a6abf7158809cf4f3c -iv 000102030405060708090a0b0c0d0e0f -e -in $DIR/$FILE -out $DIR/enc_$FILE
733 }
734

```

3) 획득한 정보들을 활용하여 암호화 해제 시도

```

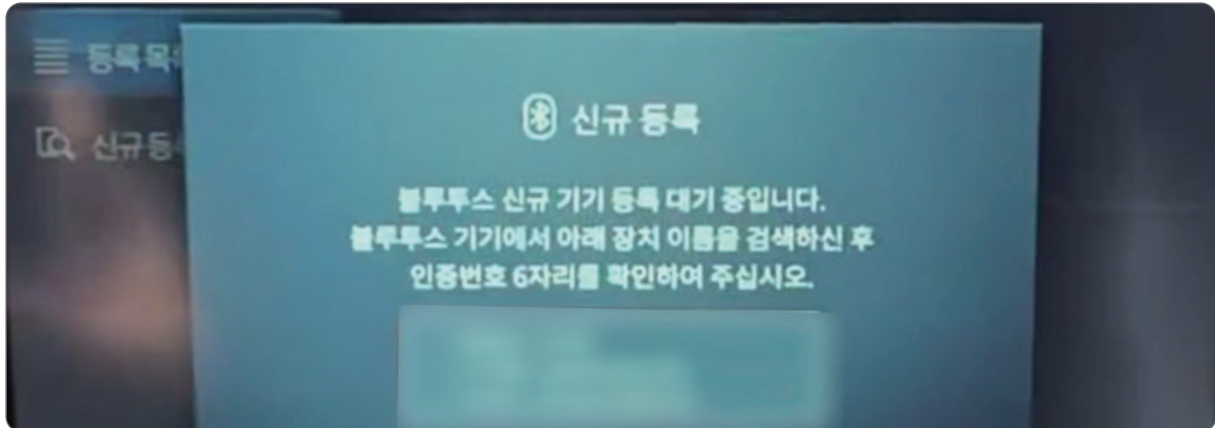
>> .\openssl.exe aes-128-cbc -K 2b7e151628aed2a6abf7158809cf4f3c -iv 000102030405060708090a0b0c0d0e0f -d -in H:\Decompi
ling\enc_system_package_098.152.211130\enc_system\enc_updateboot.img -out H:\Decompi
ling\enc_system\updateboot.img
PS C:\Program Files\OpenSSL-Win64\bin>

```

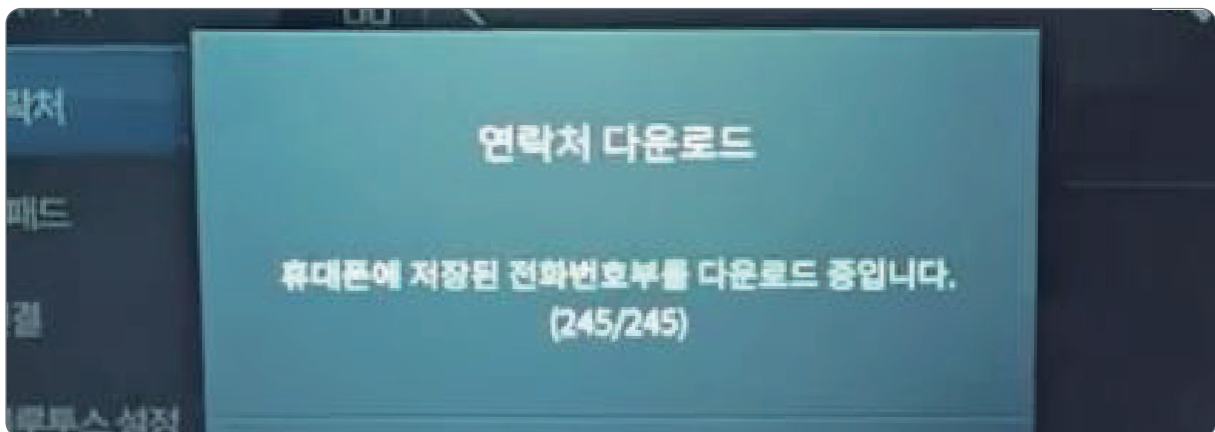
4-1-5 개인정보 보호

보안 대책	개인정보 보호
테스트케이스 명	평문으로 저장된 개인정보 확인
UN R155 Annex5	21.1/31.1
Pre-Condition	-
필요 도구	-
테스트 과정	

1) AVN에 블루투스 기기 등록



2) AVN에 스마트폰에 저장된 전화번호부 다운로드



3) 시스템 내부 접근 후 개인정보 확인

```
"contacts": [
  {
    "name": "가상 연락처 1",
    "number0": "010-1234-1111",
    "numberCount": 1,
    "typer0": "mobile"
  },
  {
    "name": "가상 연락처 2",
    "number0": "010-1234-2222",
    "numberCount": 1,
    "typer0": "mobile"
  },
  {
    "name": "가상 연락처 3",
    "number0": "010-1234-3333",
    "numberCount": 1,
```

4-1-6 시스템 중요 데이터 보호

보안 대책	시스템 중요 데이터 보호
테스트케이스 명	로그 권한 및 내 시스템 정보 또는 개인정보 노출 여부 확인
UN R155 Annex5	21.1/31.1
Pre-Condition	Shell 또는 디버그 인터페이스 접근
필요 도구	시리얼 통신 장비
테스트 과정	

1) PCB에 장비 연결



2) 로그 확인을 위한 인터페이스 접근

```
Auto Linux BSP 1.0 s32g274ar db2 /dev/ttyLF0
s32g274ar db2 login: root
Password:
Last login: Fri Mar 9 12:35:49 UTC 2018 on ttyLF0
root@s32g274ar db2:~#
```

3) 생성되는 로그 파일의 권한 설정 확인

```

root@s32g274ardb2:/var/volatile/log# ls -al /var/volatile/log
total 32
drwxr-xr-x    2 root    root    160 Mar  9 13:05 .
drwxrwxrwt    4 root    root     80 Mar  9 12:34 ..
-rw-r-----   1 root    root   804 Mar  9 12:34 boot
-rw-r--r--    1 root    root     0 Mar  9 12:34 boot~
-rw-r--r--    1 root    root 10373 Mar  9 12:34 dmesg
-rw-r--r--    1 root    root   296 Mar  9 13:05 lastlog
-rw-----    1 root    root    64 Mar  9 13:05 tallylog
-rw-----    1 root    root  4800 Mar  9 13:05 wtmp
root@s32g274ardb2:/var/volatile/log#

```

4) 로그 메시지에 중요 정보 노출 여부 확인

```

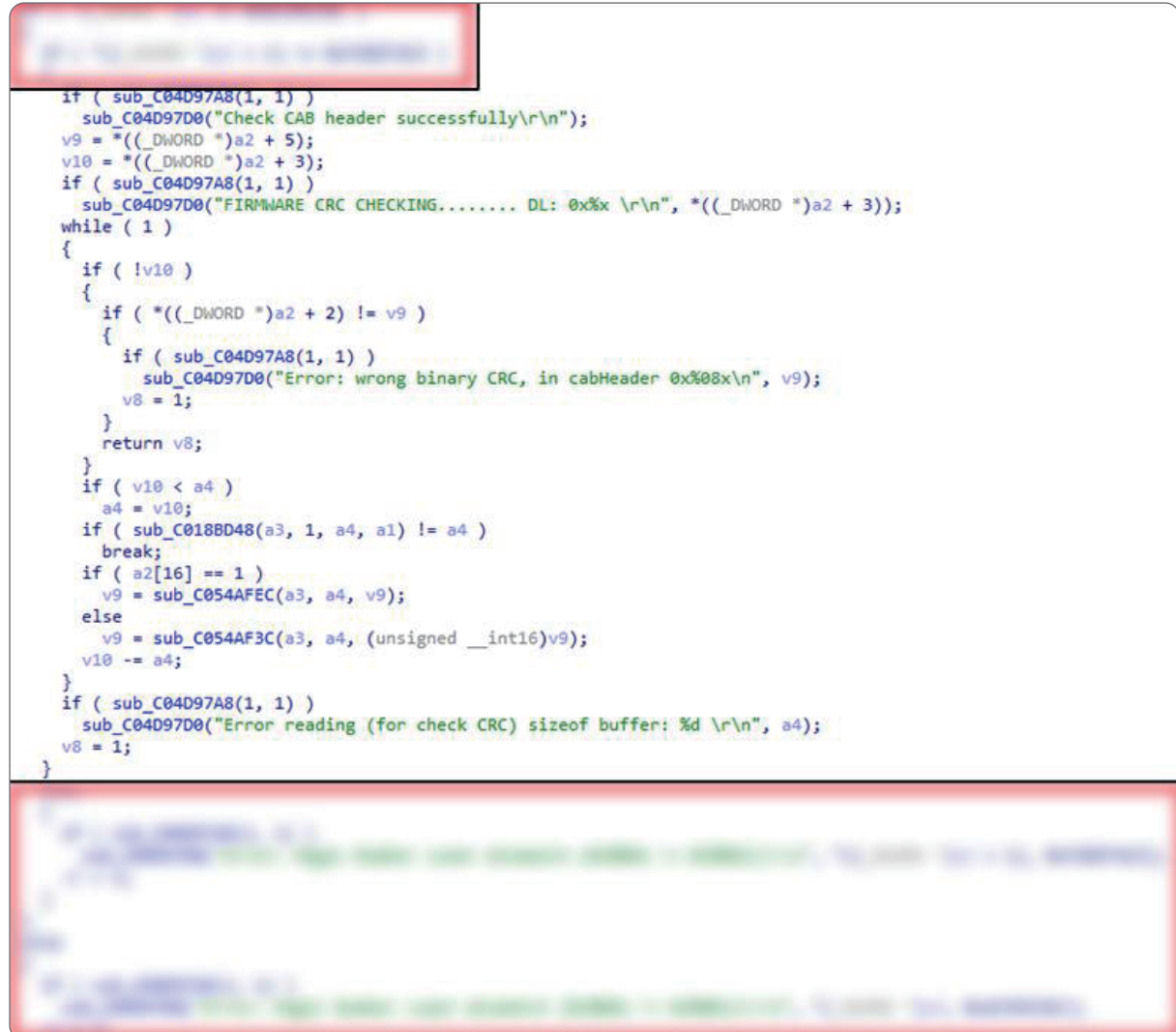
root@s32g274ardb2:/var/volatile/log# cat boot
Fri Mar  9 12:34:56 2018: Fri Mar  9 12:34:56 UTC 2018
Fri Mar  9 12:34:56 2018: urandom start: failed.
Fri Mar  9 12:34:56 2018: INIT: Entering runlevel: 3
Fri Mar  9 12:34:56 2018: Configuring network interfaces... /bin/sh: ip: not found
Fri Mar  9 12:34:56 2018: /bin/sh: ip: not found
Fri Mar  9 12:34:56 2018: Starting Simplified MAC Kernel (SMACK) ... done.
Fri Mar  9 12:34:56 2018: chmod: /var/log/lastlog: No such file or directory
Fri Mar  9 12:34:56 2018: /bin/busybox: Operation not supported
Fri Mar  9 12:34:56 2018: /bin/start_getty: Operation not supported
Fri Mar  9 12:34:56 2018: /etc/init.d/rc: /etc/rc3.d/S17chmodlog.sh: line 13: chsamck: not found
Fri Mar  9 12:34:56 2018: Starting syslogd/klogd: done
Fri Mar  9 12:34:56 2018: IPCF shm module loading & kernel version send !done.
root@s32g274ardb2:/var/volatile/log#

```

4-1-7 업데이트 보안

보안 대책	업데이트 보안
테스트케이스 명	펌웨어 업데이트 점검
UN R155 Annex5	6.1/6.2/6.3/12.1/12.2/12.3/12.4/18.1/18.3/27.1/28.2/29.2/32.1
Pre-Condition	원본 펌웨어
필요 도구	-
테스트 과정	

1) 펌웨어 분석을 통해 업데이트 과정 분석



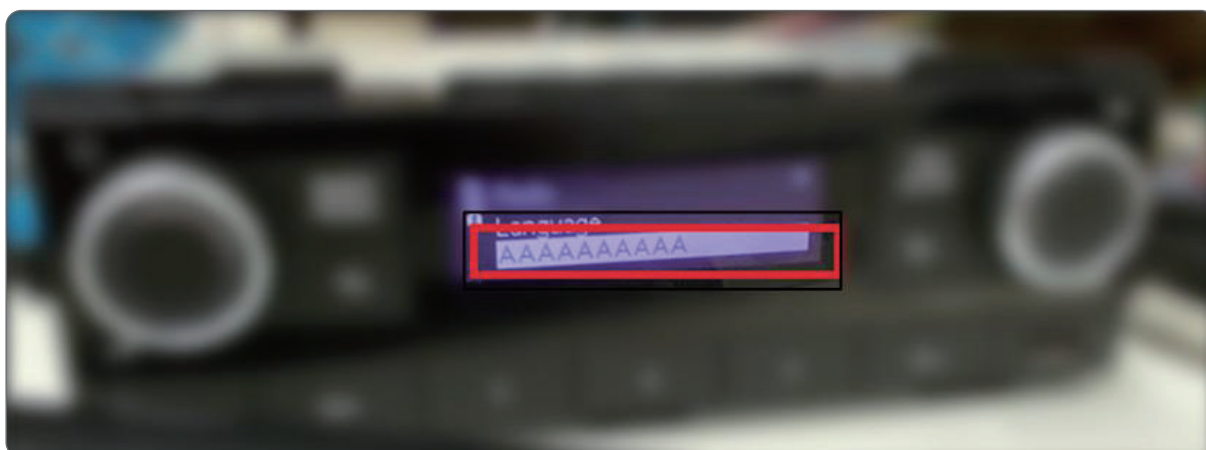
2) CRC 계산 알고리즘 분석

```

1 __int64 __fastcall GetCRC32(__int64 a1, int a2, unsigned int a3)
2 {
3     __int64 v3; // r9
4     __int64 i; // r10
5     unsigned __int8 v5; // dl
6
7     v3 = 0i64;
8     [REDACTED]
9     [REDACTED]
10    [REDACTED]
11    [REDACTED]
12
13    return a3;
14 }

```

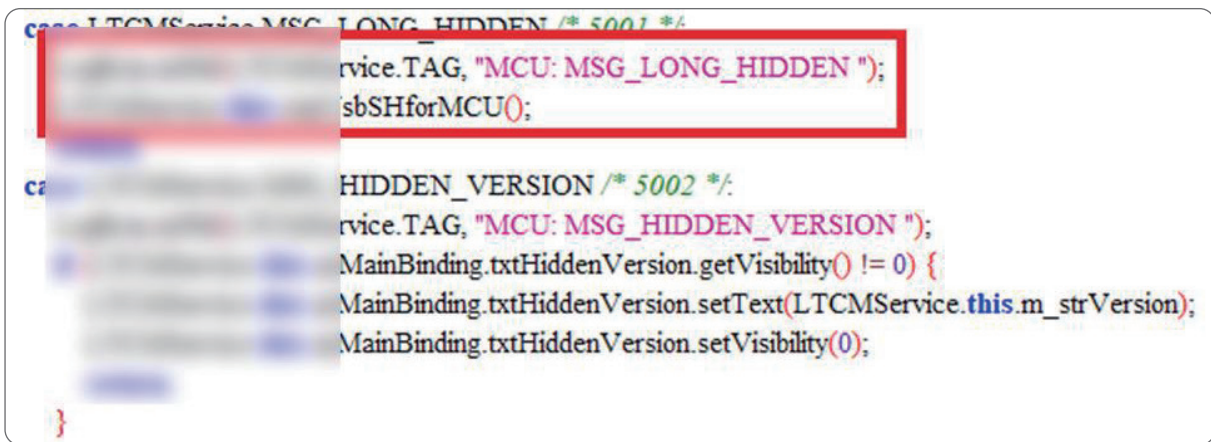
3) 업데이트 완료 후 오동작 발생 여부 확인



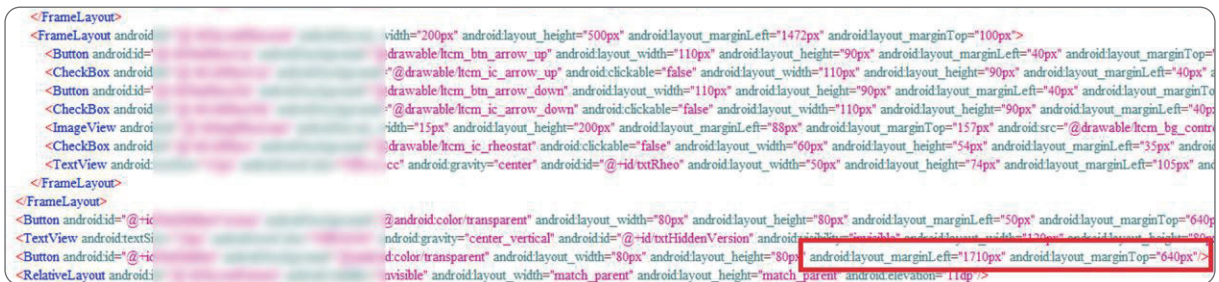
4-1-8 일반 보안

보안 대책	일반 보안
테스트케이스 명	비인가자의 개발자 디버그 모드 활성화
UN R155 Annex5	17.1/28.1/28.2
Pre-Condition	-
필요 도구	-
테스트 과정	

1) 펌웨어 또는 애플리케이션 분석을 통해 개발자 디버그 모드 존재 여부 확인



2) 해당 기능 실행 방법 확인



3) 실행 후 특수 기능 사용 가능 여부 확인



4-1-9 Secure Unlock

보안 대책	Secure Unlock
테스트케이스 명	OBD-II 포트를 이용한 UDS 권한 및 커스텀 서비스 점검
UN R155 Annex5	5.1/5.2/5.3/5.4/5.5/11.1/11.3/11.4/18.3/20.5/28.2
Pre-Condition	각 세션에서 사용 가능한 서비스 아이디 식별
필요 도구	CAN 통신을 위한 어댑터

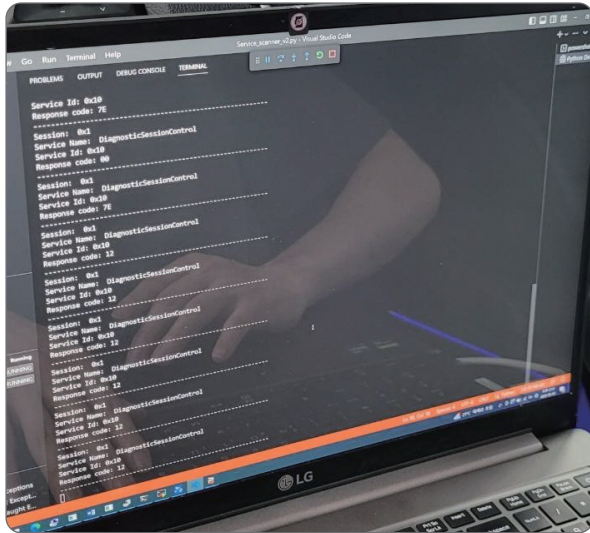
테스트 과정

1) OBD-II 포트에 분석을 위한 어댑터 연결



ISO/SAE 21434 기반 자동차
사이버보안 테스트 및 검증 매뉴얼

2) 해당 인터페이스로 UDS 메시지를 주입하여 결과 값 수집



3) 수집된 데이터를 분석하여 각 서비스 실행에 필요한 권한과 커스텀 서비스 확인

Session	Service ID	Description	Lib-function	0x0	0x1	0x2	0x3	0x4	0x5	0x6	0x7	0x8	0x9	0xa	0xb	0xc	0xd	0xe	0xf
0x1	0x10	Diagnostic	TRUE	12	00	7E	00	12	12	12	12	12	12	12	12	12	12	12	12
0x1	0x11	EcuReset	TRUE	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F
0x1	0x14	ClearDiag	FALSE	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F
0x1	0x19	ReadDTCI	TRUE	12	13	13	12	13	12	13	12	12	12	00	13	13	13	13	13
0x1	0x22	ReadData	FALSE	13	13	13	13	13	13	13	13	13	13	13	13	13	13	13	13
0x1	0x23	ReadMem	FALSE	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F
0x1	0x27	SecurityAc	TRUE	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F
0x1	0x28	Communi	TRUE	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F
0x1	0x2e	WriteData	FALSE	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F
0x1	0x31	RoutineCc	FALSE	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F
0x1	0x3d	WriteMem	FALSE	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F
0x1	0x3e	TesterPres	TRUE	00	12	12	12	12	12	12	12	12	12	12	12	12	12	12	12
0x1	0x85	ControlDT	TRUE	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F	7F
0x3	0x10	Diagnostic	TRUE	12	00	33	00	12	12	12	12	12	12	12	12	12	12	12	12
0x3	0x11	EcuReset	TRUE	33	33	33	33	33	33	33	33	33	33	33	33	33	33	33	33
0x3	0x14	ClearDiag	FALSE	33	33	33	33	33	33	33	33	33	33	33	33	33	33	33	33
0x3	0x19	ReadDTCI	TRUE	12	13	13	12	13	12	13	12	12	12	00	13	13	13	13	13
0x3	0x22	ReadData	FALSE	13	13	13	13	13	13	13	13	13	13	13	13	13	13	13	13
0x3	0x23	ReadMem	FALSE	33	33	33	33	33	33	33	33	33	33	33	33	33	33	33	33
0x3	0x27	SecurityAc	TRUE	12	12	12	12	12	12	12	22	24	12	12	12	12	12	12	12
0x3	0x28	Communi	TRUE	33	33	33	33	33	33	33	33	33	33	33	33	33	33	33	33
0x3	0x2e	WriteData	FALSE	33	33	33	33	33	33	33	33	33	33	33	33	33	33	33	33
0x3	0x31	RoutineCc	FALSE	33	33	33	33	33	33	33	33	33	33	33	33	33	33	33	33
0x3	0x3d	WriteMem	FALSE	33	33	33	33	33	33	33	33	33	33	33	33	33	33	33	33
0x3	0x3e	TesterPres	TRUE	00	12	12	12	12	12	12	12	12	12	12	12	12	12	12	12
0x3	0x85	ControlDT	TRUE	33	33	33	33	33	33	33	33	33	33	33	33	33	33	33	33

4-1-10 Secure Access

보안 대책	Secure Access
테스트케이스 명	ECU Reset을 통한 중복 시드 생성
UN R155 Annex5	9.1/18.3/20.1/20.2/20.3/20.4/20.5
Pre-Condition	Security Access 세션 및 레벨 식별
필요 도구	CAN 통신을 위한 어댑터
테스트 과정	

1) Security Access 서비스 시드 및 키 길이 확인

Time	CAN-ID	Rx/Tx	Type	Length	Data
1.8718	718h	Tx	Data	8	02 10 00 00 00 00 00
1.8837	618h	Rx	Data	8	06 50 00 32 01 F4 00
3.0759	718h	Tx	Data	8	02 10 00 00 00 00 00
3.0880	618h	Rx	Data	8	06 50 00 32 01 F4 00
4.2866	718h	Tx	Data	8	02 27 00 00 00 00 00
4.2930	618h	Rx	Data	8	05 67 06 5B 00 00 00

2) ECU Reset 서비스를 이용하여 다량의 시드 수집

1	6713212.388	DT	0618 Rx 8	06 50	00 32 01 F4 00
2	6713215.711	FB	0718 Rx 8	02 27	00 00 00 00 00
3	6713226.493	DT	0618 Rx 8	05 67	C7 8B F3 00 00
4	6713230.772	FB	0718 Rx 8	05 27	5 CC 46 00 00
5	6713241.412	DT	0618 Rx 8	03 7F	86 00 00 00 00
6	6713244.989	FB	0718 Rx 8	02 11	00 00 00 00 00
7	6713281.416	DT	0618 Rx 8	02 51	00 00 00 00 00
8	6718788.410	FB	0718 Rx 8	02 10	00 00 00 00 00
9	6718799.398	DT	0618 Rx 8	06 50	00 32 01 F4 00
10	6718802.571	FB	0718 Rx 8	02 27	00 00 00 00 00
11	6718809.364	DT	0618 Rx 8	05 67	C7 8B F3 00 00
12	6718813.166	FB	0718 Rx 8	05 27	DC 7D 49 00 00
13	6718819.424	DT	0618 Rx 8	03 7F	86 00 00 00 00
14	6718822.528	FB	0718 Rx 8	02 11	00 00 00 00 00
15	6718864.289	DT	0618 Rx 8	02 51	00 00 00 00 00
16	6724370.041	FB	0718 Rx 8	02 10	00 00 00 00 00
17	6724384.840	DT	0618 Rx 8	06 50	00 32 01 F4 00
18	6724387.369	FB	0718 Rx 8	02 27	00 00 00 00 00
19	6724393.854	DT	0618 Rx 8	05 67	01 E9 75 00 00
20	6724398.168	FB	0718 Rx 8	05 27	9 4F BB 00 00
21	6724409.003	DT	0618 Rx 8	03 7F	86 00 00 00 00
22	6724412.481	FB	0718 Rx 8	02 11	00 00 00 00 00
23	6724453.868	DT	0618 Rx 8	02 51	00 00 00 00 00

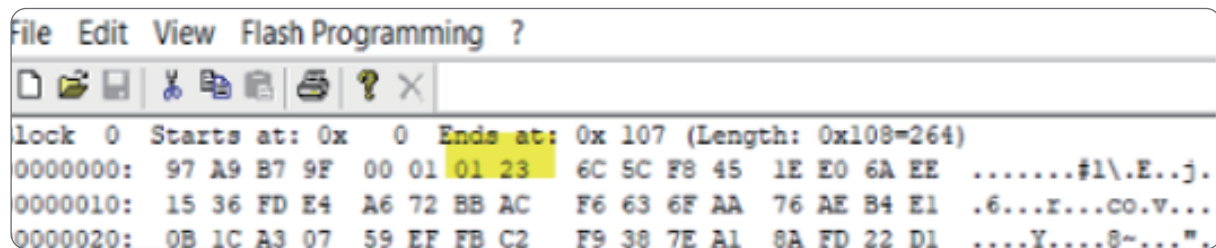
3) 수집된 시드 값을 분석하여 중복 시드 확인

13638	Seed:	14:15:13.395735	C7	F3
13639	Seed:	14:15:18.980698	3A	F7
13640	Seed:	14:15:24.572979	3A	F7
13641	Seed:	14:15:30.173244	C7	F3
13642	Seed:	14:15:35.764688	01	75
13643	Seed:	14:15:41.355904	3A	F7
13644	Seed:	14:15:46.944248	74	7A
13645	Seed:	14:15:52.538182	3A	F7
13646	Seed:	14:15:58.123196	74	7A
13647	Seed:	14:16:03.718165	74	7A
13648	Seed:	14:16:09.307352	AE	FC
13649	Seed:	14:16:14.889225	AE	FC
13650	Seed:	14:16:20.473324	AE	FC
13651	Seed:	14:16:26.059270	74	7A
13652	Seed:	14:16:31.886351	00	01
13653	Seed:	14:16:37.464222	00	01
13654	Seed:	14:16:43.042230	00	01
13655	Seed:	14:16:48.612142	01	75
13656	Seed:	14:16:54.207640	C7	F3
13657	Seed:	14:16:59.790640	3A	F7
13658	Seed:	14:17:05.377474	3A	F7
13659	Seed:	14:17:10.960695	3A	F7

4-1-11 Secure Flash

보안 대책	Secure Flash
테스트케이스 명	UDS 서비스를 통한 변조된 펌웨어 업데이트
UN R155 Annex5	6.1/6.2/6.3/11.3/12.2/12.3/12.4/18.3
Pre-Condition	펌웨어 업데이트를 위한 UDS 서비스 식별
필요 도구	CAN 통신을 위한 어댑터
테스트 과정	

1) Security Access 서비스 시드 및 키 길이 확인



2) 변조된 펌웨어를 이용하여 리프로그래밍 수행

ogs		
2/22 13:10:16.719	SUCCESS	Security Access Level 4 ... Successfully Completed.
2/22 13:10:16.772	SUCCESS	Write Tester Serial Number ... Successfully Completed.
2/22 13:10:16.824	SUCCESS	Write Programming Date ... Successfully Completed.
2/22 13:10:16.826	WARNING	Start Routine (Routine Control - Erase flash sector) ... Please Wait.
2/22 13:10:17.694	SUCCESS	Start Routine (Routine Control - Erase flash sector) ... Successfully Completed.
2/22 13:10:17.703	SUCCESS	Request Download ... Successfully Completed.
2/22 13:11:19.467	SUCCESS	Transfer Data ... Successfully Completed.
2/22 13:11:19.468	SUCCESS	Transfer Exit ... Successfully Completed.

3) Secure Flash로 인한 리프로그래밍 취소 여부 확인

2/22 13:11:20.558	ERROR	Start Routine (CheckMemory) Failed - Not Defined!
2/22 13:11:24.479	ERROR	Response Timeout error occurred in ...Start Routine(Routine Control-Check Memory)
2/22 13:11:24.481	SUCCESS	Successfully Go Off Bus
2/22 13:11:25.85	ERROR	Downloading Interrupted.....
2/22 13:13:50.854	WARNING	Diagnostic Mode not started! Please Start

4-1-12 Secure Boot

보안 대책	Secure Boot
테스트케이스 명	디버그 인터페이스를 통한 부트로더 변조
UN R155 Annex5	12.2/12.3/12.4/18.1/27.1/28.2/32.1
Pre-Condition	활성화된 디버그 인터페이스
필요 도구	JTAG 디버거
테스트 과정	

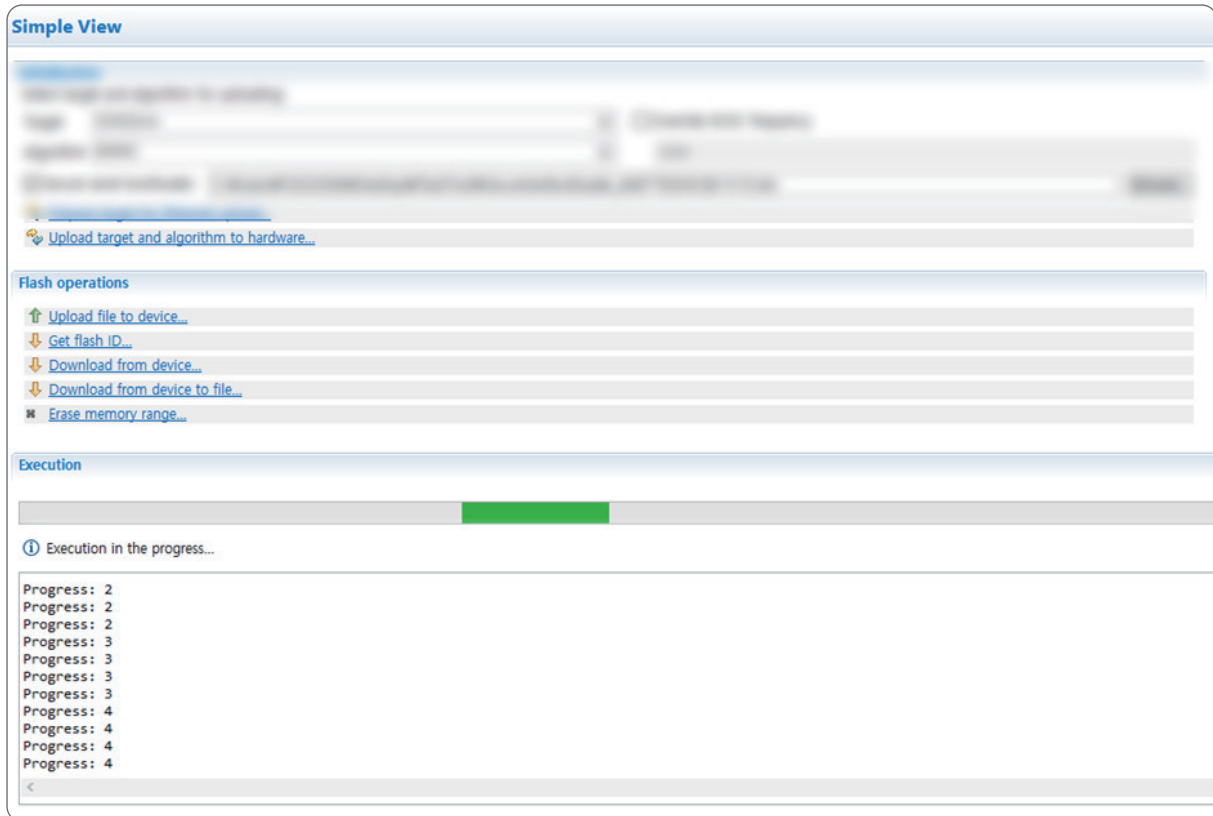
1) 디버그 인터페이스를 통해 플래시 덤프

파일(F) 편집(E) 찾기(S) 보기(V) 분석(A) 도구(T) 창 설정(W) 도움말(H)																	
dump.bin																	
Offset(h) 00 01 02 03 04 05 06 07 08 09 0A 0B 0C 0D 0E 0F Decoded text																	
00000480 00 00 00 03 00 00 00 12 00 00 00 2C 46 72 65 65Free																	
00000490 73 63 61 6C 65 20 53 33 32 47 32 37 34 00 00 00 scale S32G274...																	
000004A0 00 00 00 03 00 00 00 43 00 00 00 32 66 73 6C 2CC...2fsl,																	
000004B0 73 33 32 67 32 37 34 2D 73 69 6D 75 00 66 73 6C s32g274-simu.fsl																	
000004C0 2C 73 33 32 67 32 37 34 00 61 72 6D 2C 76 65 78 ,s32g274.arm,vex																	
000004D0 70 72 65 73 73 2C 76 32 70 2D 61 61 72 63 68 36 press,v2p-aarch6																	
000004E0 34 00 61 72 6D 2C 76 65 78 70 72 65 73 73 00 00 4.arm,vexpress..																	
000004F0 00 00 00 01 61 6C 69 61 73 65 73 00 00 00 00 03aliases.....																	
00000500 00 00 00 12 00 00 00 3D 2F 66 6C 65 78 63 61 6E=/flexcan																	
00000510 40 34 30 31 42 34 30 30 30 00 00 00 00 00 00 03 @401B4000.....																	
00000520 00 00 00 12 00 00 00 42 2F 66 6C 65 78 63 61 6EB/flexcan																	
00000530 40 34 30 31 42 45 30 30 30 00 00 00 00 00 00 03 @401BE000.....																	
00000540 00 00 00 12 00 00 00 47 2F 66 6C 65 78 63 61 6EG/flexcan																	
00000550 40 34 30 32 41 38 30 30 30 00 00 00 00 00 00 03 @402A8000.....																	
00000560 00 00 00 12 00 00 00 4C 2F 66 6C 65 78 63 61 6EL/flexcan																	
00000570 40 34 30 32 42 32 30 30 30 00 00 00 00 00 00 03 @402B2000.....																	
00000580 00 00 00 11 00 00 00 51 2F 73 65 72 69 61 6C 40Q/serial@																	
00000590 34 30 31 43 38 30 30 30 00 00 00 00 00 00 00 03 401C8000.....																	
000005A0 00 00 00 0F 00 00 00 59 2F 63 6C 6B 73 40 34 30Y/clks@40																	
000005B0 30 33 38 30 30 30 00 00 00 00 00 03 00 00 00 0E 038000.....																	
000005C0 00 00 00 5E 2F 72 67 6D 40 34 30 30 37 38 30 30 ...~/rgm@4007800																	
000005D0 30 00 00 00 00 00 00 03 00 00 00 0F 00 00 00 64 0.....d																	
000005E0 2F 70 63 69 65 40 34 30 34 30 30 30 30 00 00 /pcie@40400000...																	

2) 덤프한 파일에서 부트 이미지 추출

29599	0x739F	LZMA compressed data, properties: 0x9B, dictionary size: 0 bytes, uncompressed size: 12355
bytes		
29691	0x73FB	LZMA compressed data, properties: 0x9B, dictionary size: 0 bytes, uncompressed size: 32835
bytes		
29791	0x745F	LZMA compressed data, properties: 0x9B, dictionary size: 0 bytes, uncompressed size: 33859
bytes		
33792	0x8400	gzip compressed data, maximum compression, has original file name: "Image", last modified: 2023-08-30
2307891	0x233733	CRC32 polynomial table, little endian
3044352	0x2E7400	uImage header, header size: 64 bytes, header CRC: 0x7CE68085, created: 1970-01-01 00:00:00, image size: 8914776 bytes, Data Address: 0x0, Entry Point: 0x0, data CRC: 0x8045FFF2, OS: Linux, image type: RAMDisk : image, compression type: none, image name: "fsl-image-base-s32g274ardb2-2023"
3044416	0x2E7440	gzip compressed data, maximum compression, from Unix, last modified: 1970-01-01 00:00:00 (null date)
5850724	0x594664	CRC32 polynomial table, little endian
8672007	0x845307	LZMA compressed data, properties: 0x5D, dictionary size: 0 bytes, uncompressed size: 79641
25822103781375		bytes

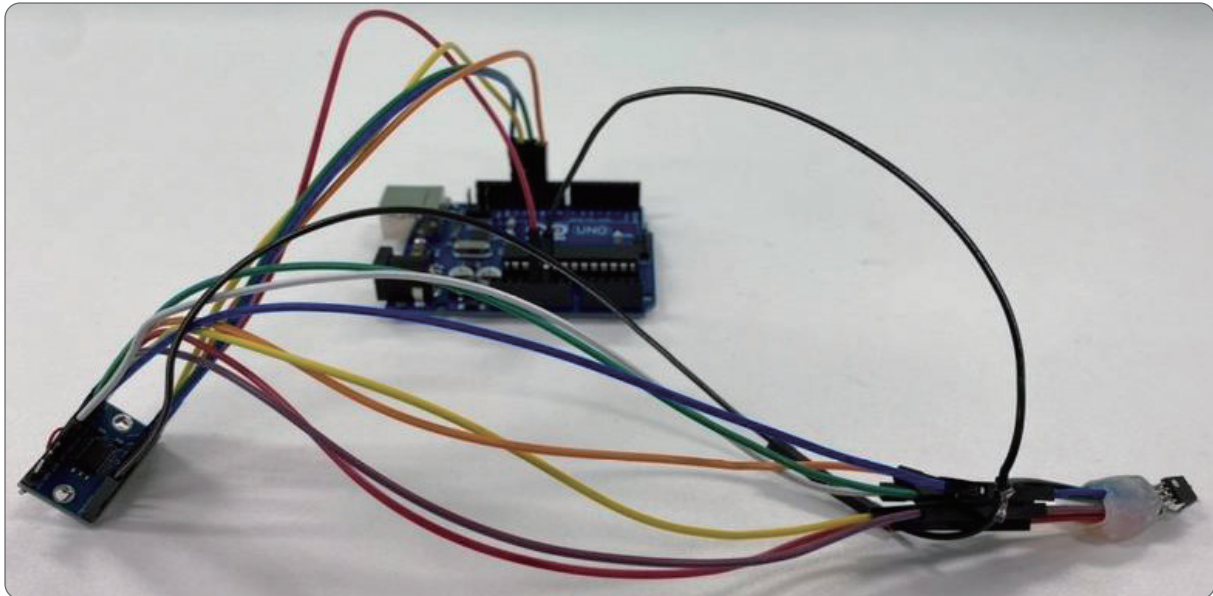
5) 변조된 이미지 플래시 후 결과 확인



4-1-13 Secure Storage

보안 대책	Secure Storage
테스트케이스 명	Storage 내 중요정보 암호화 여부 점검
UN R155 Annex5	19.2
Pre-Condition	-
필요 도구	-
테스트 과정	

1) Storage Dump를 통해 데이터 추출



2) 특정 주소의 데이터 암호화 확인 및 우회

00	04	00	00	18	01	00	00	00	10	00	00	00	30	05	00
00	00	4C	00	00	00	0E	00	00	00	00	00	00	00	00	00

3) 덤프 파일에서 파일 추출

 history201_202308.db	2023-08-29 오후 9:14	DB 파일	13KB
 history201_202309.db	2023-09-09 오후 1:42	DB 파일	20KB
 history201_202310.db	2023-10-06 오전 10:53	DB 파일	13KB
 offlineMessageDB.db	2023-09-09 오후 1:23	DB 파일	2KB
 payment.db	2023-09-08 오후 3:44	DB 파일	0KB
 payment_202308.db	2023-08-28 오후 7:48	DB 파일	2KB
 payment_202309.db	2023-09-09 오후 1:43	DB 파일	8KB
 payment_202310.db	2023-10-06 오전 10:53	DB 파일	2KB
 session201_202308.db	2023-08-29 오후 9:14	DB 파일	3KB
 session201_202309.db	2023-09-09 오후 1:43	DB 파일	5KB
 session201_202310.db	2023-10-06 오전 10:53	DB 파일	3KB

4) 중요정보 식별

가. 운전자 개인 정보

나. 결제 관련 정보

다. 차량 고유 식별 정보

라. 차량 주행 관련 데이터

마. 차량 주요 기능 설정 값

바. 차량 주요 매개변수

사. 시스템 이벤트 로그

아. 제어기 펌웨어

테이블(T): chgLog

필터	szSessionId	authMethod	authLocation	authStart	authFinish	authType	szAuthnumber	authResult	pwrMeterValueAtStart	pwrMet
필터	필터	필터	필터	필터	필터	필터	필터	필터	필터	필터
13	202309081604371	4	NULL	2023-09-08T16:04:37.887	2023-09-08T16:05:06.731	4	NULL	1		0.0
14	202309081608261	4	NULL	2023-09-08T16:08:26.572	2023-09-08T16:08:33.526	4	NULL	1		0.0
15	202309081636431	4	NULL	2023-09-08T16:36:43.234	2023-09-08T16:36:55.018	4	NULL	1		0.0
16	202309090918311	4	NULL	2023-09-09T09:18:31.105	2023-09-09T09:18:42.075	4	NULL	1		7671.0
17	202309091002191	4	NULL	2023-09-09T10:02:19.770	2023-09-09T10:02:31.551	4	NULL	1		7921.0
18	202309091036421	4	NULL	2023-09-09T10:36:42.775	2023-09-09T10:36:50.511	4	NULL	1		8457.0
19	202309091101281	4	NULL	2023-09-09T11:01:28.108	2023-09-09T11:01:39.874	4	NULL	1		0.0
20	202309091103081	4	NULL	2023-09-09T11:03:08.625	2023-09-09T11:03:16.334	4	NULL	1		8590.0
21	202309091107551	4	NULL	2023-09-09T11:07:55.290	2023-09-09T11:08:02.590	4	NULL	1		0.0
22	202309091110471	4	NULL	2023-09-09T11:10:47.172	2023-09-09T11:10:58.149	4	NULL	1		0.0
23	202309091119121	4	NULL	2023-09-09T11:19:12.245	2023-09-09T11:19:20.763	4	NULL	1		9186.0
24	202309091125011	4	NULL	2023-09-09T11:25:01.169	2023-09-09T11:25:11.768	4	NULL	1		9898.0
25	202309091144331	4	NULL	2023-09-09T11:44:33.483	2023-09-09T11:44:50.961	4	NULL	1		NULL
26	202309091155571	4	NULL	2023-09-09T11:55:57.809	2023-09-09T11:56:16.906	4	NULL	1		11166.0
27	202309091159361	4	NULL	2023-09-09T11:59:36.084	2023-09-09T11:59:47.054	4	NULL	1		11480.0
28	202309091241361	4	NULL	2023-09-09T12:41:36.341	2023-09-09T12:41:48.123	4	NULL	1		11730.0
29	202309091245031	4	NULL	2023-09-09T12:45:03.174	2023-09-09T12:45:13.774	4	NULL	1		12753.0
30	202309091246511	4	NULL	2023-09-09T12:46:51.792	2023-09-09T12:47:07.228	4	NULL	1		0.0

4-1-14 Run-Time Tuning Protection

보안 대책	Run-Time Tuning Protection
테스트케이스 명	런타임 메모리 번조를 통한 루트 쉘 접근
UN R155 Annex5	18.2/22.2/23.1/27.1
Pre-Condition	디버그 인터페이스 접근
필요 도구	범용 디버거
테스트 과정	

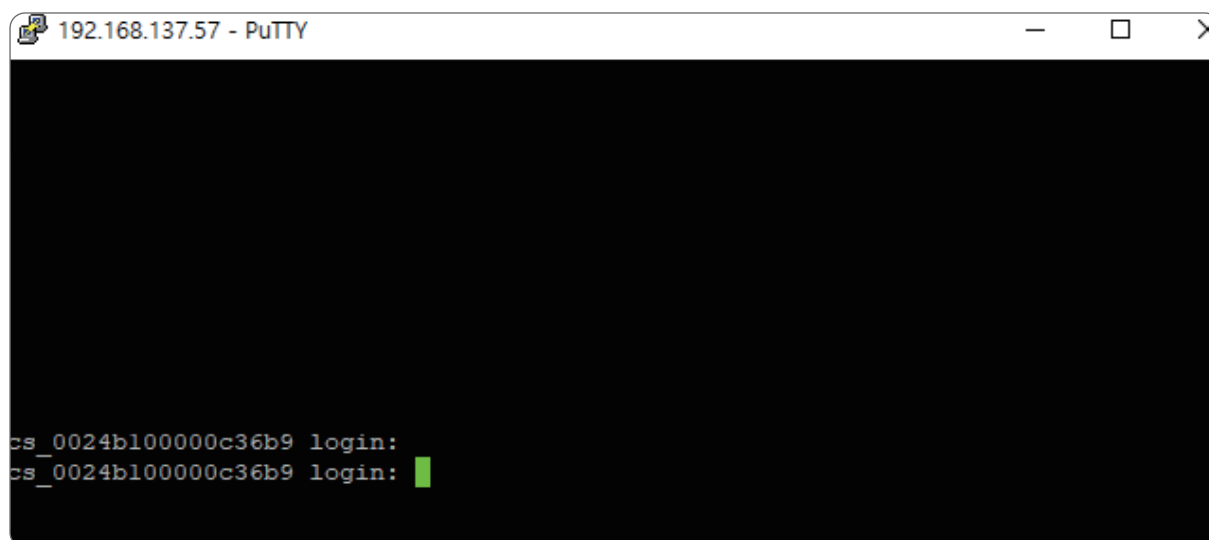
1) 범용 디버거를 이용하여 메모리 영역 덤프

Offset(h)	00	01	02	03	04	05	06	07	08	09	0A	0B	0C	0D	0E	0F	Decoded text
00000000	B2	31	4B	E1	0C	30	1B	E5	02	20	83	E2	0C	20	0B	E5	°lKá.0.ă. fâ. .ă
00000010	B2	21	5B	E1	B4	21	4B	E1	B4	21	5B	E1	02	18	A0	E1	°![á'!Ká'![á.. á
00000020	21	18	A0	E1	21	14	A0	E1	02	24	A0	E1	02	20	81	E1	!. á!. á.\$ á. .á
00000030	B6	21	4B	E1	B6	21	5B	E1	B0	20	C3	E1	08	20	1B	E5	¶!Ká¶![á° Āá. .ă
00000040	10	30	1B	E5	03	00	52	E1	E8	FF	FF	3A	00	D0	4B	E2	.0.ă..Râèÿÿ:ĐKâ
00000050	04	B0	9D	E4	1E	FF	2F	E1	00	48	2D	E9	04	B0	8D	E2	.°.ă.ÿ/á.H-é.°.ă
00000060	10	D0	4D	E2	00	30	A0	E3	10	30	0B	E5	80	31	9F	E5	.ĐMâ.0 .ă.0.ă€lŸă
00000070	03	30	8F	E0	03	00	A0	E1	38	58	FE	EB	08	00	0B	E5	.0.ă.. á8Xpě...ă
00000080	00	30	A0	E3	0C	30	0B	E5	08	30	1B	E5	00	00	53	E3	.0 .ă.0.ă.0.ă..Să
00000090	2C	00	00	0A	20	00	00	EA	10	30	1B	E5	00	30	93	E5	,... ..ê.0.ă.0"ă
000000A0	00	30	D3	E5	63	00	53	E3	1B	00	00	1A	10	30	1B	E5	.0Ōăc.Să.....0.ă
000000B0	00	30	93	E5	01	30	83	E2	00	30	D3	E5	70	00	53	E3	.0"ă.0fă.0Ōăp.Să
000000C0	15	00	00	1A	10	30	1B	E5	00	30	93	E5	02	30	83	E2	0.ă.0"ă.0fă
000000D0	00	30	D3	E5	75	00	53	E3	0F	00	00	1A	14	31	9F	E5	.0Ōău.Să.....lŸă
000000E0	03	30	8F	E0	00	20	93	E5	10	30	1B	E5	00	30	93	E5	.0.ă. "ă.0.ă.0"ă
000000F0	03	30	83	E2	00	30	D3	E5	83	30	A0	E1	03	30	82	E0	.0fă.0Ōăf0 á.0,à
00000100	B0	30	D3	E1	08	30	03	E2	00	00	53	E3	02	00	00	0A	°ŌŌă.0.ă..Să....
00000110	0C	30	1B	E5	01	30	83	E2	0C	30	0B	E5	10	30	4B	E2	.0.ă.0fă.0.ă.0Kâ
00000120	08	00	1B	E5	03	10	A0	E1	CC	20	9F	E5	CC	30	9F	E5	...ă.. áİ ŸăİŸă
00000130	03	30	8F	E0	46	58	FE	EB	00	30	A0	E1	00	00	53	E3	.0.ăFXpě.0 á..Să
00000140	D4	FF	FF	1A	1F	00	00	EA	B4	30	9F	E5	03	30	8F	E0	Ōÿÿ....ê°Ÿă.0.ă
00000150	03	00	A0	E1	01	58	FE	EB	08	00	0B	E5	08	30	1B	E5	.. á.Xpě...ă.0.ă
00000160	00	00	53	E3	17	00	00	0A	0C	00	00	EA	10	30	1B	E5	..Să.....ê.0.ă
00000170	00	30	93	E5	8C	20	9F	E5	02	20	8F	E0	02	00	A0	E1	.0"ăŒ Ÿă. .à.. á
00000180	03	10	A0	E1	ED	32	FF	EB	00	30	A0	E1	00	00	53	E3	.. áí2ÿě.0 á..Să
00000190	02	00	00	1A	0C	30	1B	E5	01	30	83	E2	0C	30	0B	E5	0.ă.0fă.0.ă
000001A0	10	30	4B	E2	08	00	1B	E5	03	10	A0	E1	58	20	9F	E5	.0Kâ...ă.. áX Ÿă
000001B0	58	30	9F	E5	03	30	8F	E0	25	58	FE	EB	00	30	A0	E1	XŌŸă.0.ăXpě.0 á
000001C0	00	00	53	E3	E8	FF	FF	1A	08	00	1B	E5	09	58	FE	EB	..Săèÿÿ....ă.Xpě
000001D0	0C	30	1B	E5	00	00	53	E3	01	00	00	0A	0C	30	1B	E5	.0.ă..Să.....0.ă
000001E0	00	00	00	EA	01	30	A0	E3	03	00	A0	E1	04	D0	4B	E2	...ê.0 .ă.. á.ĐKâ
000001F0	00	88	BD	E8	88	A6	00	00	64	2F	01	00	02	01	00	00	.^è^!...d/.....
00000200	D4	A5	00	00	BC	A5	00	00	A0	A5	00	00	02	02	07	00	ŌŸ...Ÿ... Ÿ.....

2) 덤프 파일 내부에서 루트 계정과 관련된 데이터가 저장된 물리 주소 확인

07CD2FF0	00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00	
07CD3000	72 6F 6F 74 3A 78 3A 30 3A 30 3A 72 6F 6F 74 3A	root:x:0:0:root:
07CD3010	2F 72 6F 6F 74 3A 2F 62 69 6E 2F 73 68 0A 64 61	/usr/bin/sh.da
07CD3020	65 6D 6F 6E 3A 78 3A 31 3A 31 3A 64 61 65 6D 6F	emon:x:1:1:daemo
07CD3030	6E 3A 2F 75 73 72 2F 73 62 69 6E 3A 2F 62 69 6E	n:/usr/sbin:/bin
07CD3040	2F 73 68 0A 62 69 6E 3A 78 3A 32 3A 32 3A 62 69	/sh.bin:x:2:2:bi
07CD3050	6E 3A 2F 62 69 6E 3A 2F 62 69 6E 2F 73 68 0A 73	n:/bin:/bin/sh.s
07CD3060	79 73 3A 78 3A 33 3A 33 3A 73 79 73 3A 2F 64 65	ys:x:3:3:sys:/de
07CD3070	76 3A 2F 62 69 6E 2F 73 68 0A 73 79 6E 63 3A 78	v:/bin/sh.sync:x
07CD3080	3A 34 3A 31 30 30 3A 73 79 6E 63 3A 2F 62 69 6E	:4:100:sync:/bin
07CD3090	3A 2F 62 69 6E 2F 73 79 6E 63 0A 6D 61 69 6C 3A	:/bin/sync.mail:
07CD30A0	78 3A 38 3A 38 3A 6D 61 69 6C 3A 2F 76 61 72 2F	x:8:8:mail:/var/
07CD30B0	73 70 6F 6F 6C 2F 6D 61 69 6C 3A 2F 62 69 6E 2F	spool/mail:/bin/
07CD30C0	73 68 0A 70 72 6F 78 79 3A 78 3A 31 33 3A 31 33	sh.proxy:x:13:13
07CD30D0	3A 70 72 6F 78 79 3A 2F 62 69 6E 3A 2F 62 69 6E	:proxy:/bin:/bin
07CD30E0	2F 73 68 0A 77 77 77 2D 64 61 74 61 3A 78 3A 33	/sh.www-data:x:3
07CD30F0	33 3A 33 33 3A 77 77 77 2D 64 61 74 61 3A 2F 76	3:33:www-data:/v
07CD3100	61 72 2F 77 77 77 3A 2F 62 69 6E 2F 73 68 0A 62	ar/www:/bin/sh.b
07CD3110	61 63 6B 75 70 3A 78 3A 33 34 3A 33 34 3A 62 61	ackup:x:34:34:ba
07CD3120	63 6B 75 70 3A 2F 76 61 72 2F 62 61 63 6B 75 70	ckup:/var/backup
07CD3130	73 3A 2F 62 69 6E 2F 73 68 0A 6F 70 65 72 61 74	s:/bin/sh.operat
07CD3140	6F 72 3A 78 3A 33 37 3A 33 37 3A 4F 70 65 72 61	or:x:37:37:Opera
07CD3150	74 6F 72 3A 2F 76 61 72 3A 2F 62 69 6E 2F 73 68	tor:/var:/bin/sh
07CD3160	0A 68 61 6C 64 61 65 6D 6F 6E 3A 78 3A 36 38 3A	.haldaemon:x:68:

3) 루트 계정 검증과 관련된 프로세스 실행 중에 특정 메모리 영역 변조



4) 루트 쉘 접근 후 결과 확인

```

192.168.137.57 - PuTTY

cs_0024b100000c36b9 login: root
# whoami
root
# od
^C
# id
uid=0(root) gid=0(root) groups=0(root),10(wheel)

```

4-1-15 Secure Debug

보안 대책	Secure Debug
테스트케이스 명	디버그 인터페이스 및 Shell 접근 가능 여부 점검
UN R155 Annex5	9.1/18.1/19.1/19.2/28.2/31.1
Pre-Condition	활성화된 디버그 포트 또는 테스트포인트 식별
필요 도구	디버그 인터페이스 접근을 위한 디버거, JTAGulator
테스트 과정	

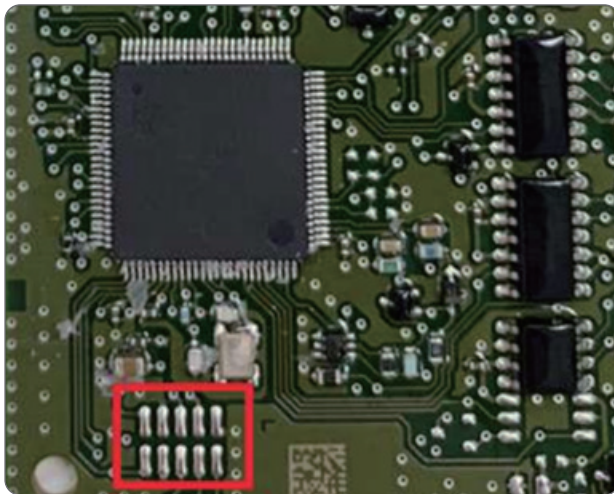
1) PCB에서 메인 칩 식별



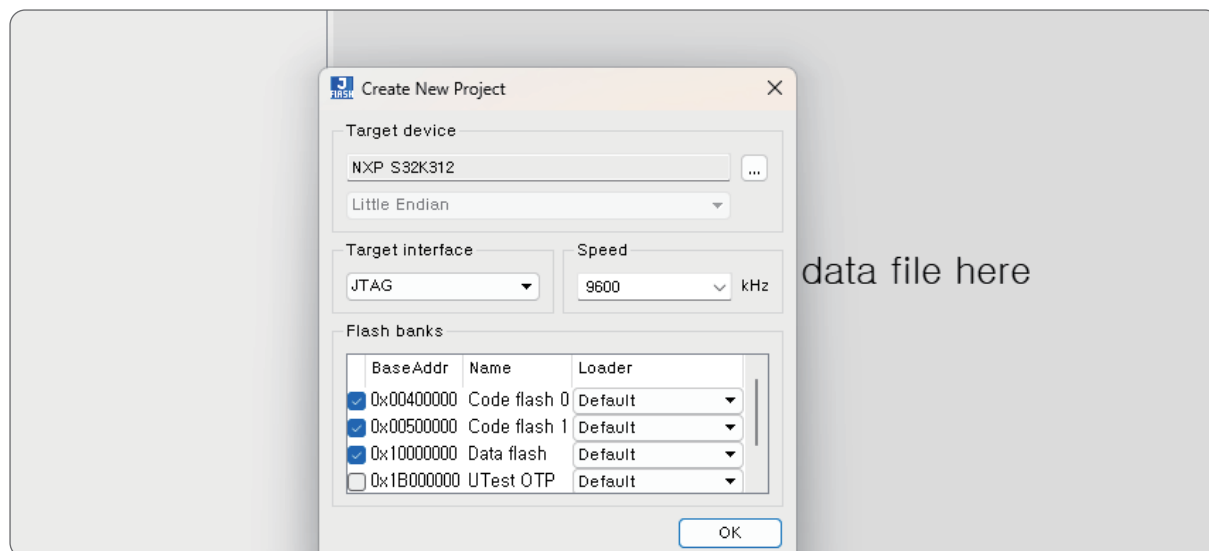
2) 데이터 시트에서 디버그 정보 식별

162	91	160	PTA11	GPIO[11]	GPIO[11]
163	92	161	PTA10	JTAG_TDO/TRACEnoETM_SWO	GPIO[10]
164	93	162	PTE1	GPIO[129]	GPIO[129]
165	94	163	PTE0	GPIO[128]	GPIO[128]
166		164	PTE26	GPIO[154]	GPIO[154]
167	95	165	PTC5	JTAG_TDI	GPIO[69]
168	96	166	PTC4	JTAG_TCK/SWD_CLK	GPIO[68]
169	97	167	PTA5	RESET_b	GPIO[5]
170		168	VSS	VSS	
171		169	VDD_HV_A	VDD_HV_A	
172	98	170	PTA4	JTAG_TMS/SWD_DIO	GPIO[4]
173	99	171	PTA9	GPIO[9]	GPIO[9]
174	100	172	PTA8	GPIO[8]	GPIO[8]

3) PCB 보드 위의 디버그 인터페이스 식별



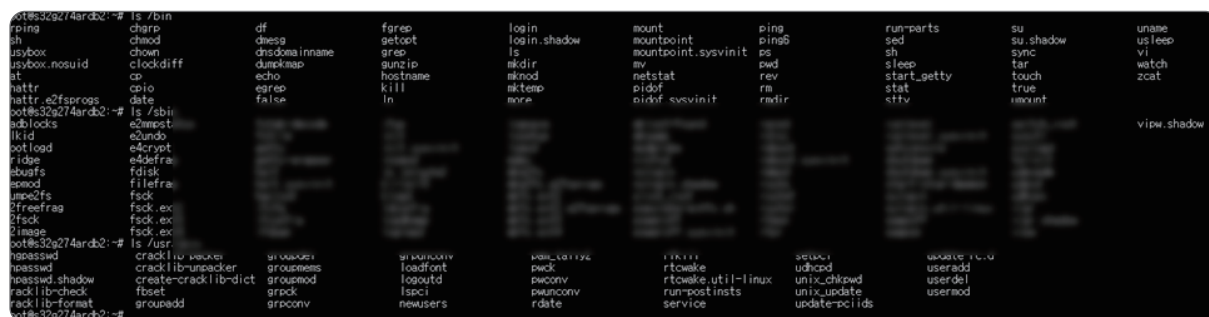
4) 디버그 포트를 이용하여 디버깅 기능 사용 시도



4-1-16 Memory Protection

보안 대책	Memory Protection
테스트케이스 명	메모리 보호 기법 점검
UN R155 Annex5	24.1/25.1/25.2/27.1
Pre-Condition	Shell 접근
필요 도구	-
테스트 과정	

1) 주요 바이너리 파일 식별



2) Checksec과 같은 점검 스크립트를 이용하여 스택 실행 권한 제거 설정 여부 확인

```
root@mermaid-VirtualBox:/home/dump/filesystem/bin# checksec cat cmd date echo
[!] Could not populate PLT: invalid syntax (unicorn.py, line 110)
[*] '/home/dump/filesystem/bin/cat'
  Arch:      aarch64-64-little
  RELRO:     Full RELRO
  Stack:     Canary found
  NX:        NX enabled
  PIE:       PIE enabled
[!] Could not populate PLT: cannot import name arm_const
[*] '/home/dump/filesystem/bin/cmd'
  Arch:      aarch64-64-little
  RELRO:     Full RELRO
  Stack:     Canary found
  NX:        NX enabled
  PIE:       PIE enabled
[!] Could not populate PLT: cannot import name arm_const
[*] '/home/dump/filesystem/bin/date'
  Arch:      aarch64-64-little
  RELRO:     Full RELRO
  Stack:     Canary found
  NX:        NX enabled
  PIE:       PIE enabled
[!] Could not populate PLT: cannot import name arm_const
[*] '/home/dump/filesystem/bin/echo'
  Arch:      aarch64-64-little
  RELRO:     Full RELRO
  Stack:     Canary found
  NX:        NX enabled
  PIE:       PIE enabled
```


4-1-17 HSM

보안 대책	HSM
테스트케이스 명	HSM 영역 접근 가능 여부 확인
UN R155 Annex5	19.3/26.1/26.2/26.3
Pre-Condition	플래시 덤프 파일 획득
필요 도구	-
테스트 과정	

1) 데이터시트에서 HSM 영역 주소 확인

Table 138. IVT image structure (continued)

Address	Size (bytes)	Name	Comments
10h	4	DCD pointer	Pointer to the start of DCD configuration data
14h	4	DCD pointer (backup)	Pointer to the start of backup DCD configuration data
18h	4	HSE_H firmware flash memory start pointer	Pointer to the start of the HSE_H firmware in flash memory
1Ch	4	HSE_H firmware flash memory start pointer (backup)	Pointer to the start of the backup HSE_H firmware in flash memory
20h	4	Application boot code flash memory start pointer	Pointer to the start of the application boot code in flash memory
24h	4	Application boot code flash memory start pointer (backup)	Pointer to the start of the backup application boot code in flash memory
28h	4	Boot configuration word	Configuration data used to select the boot configuration
2Ch	4	Life cycle configuration word	Configuration data used for advancing life cycle
30h	4	Reserved	Reserved
34h	32	Reserved for HSE_H firmware	Defined by the HSE_H firmware specification
54h	156	Reserved	Reserved
F0h	16	Galois Message Authentication Code (GMAC)	GMAC of first 240 bytes of IVT image structure

2) 덤프 파일에서 HSM 식별 및 수정 시도

```

ROM:00001040 ; -----
ROM:00001040          CODE16
ROM:00001040          MOV5          R1, #0xA5
ROM:00001042          LSRS          R6, R5, #7
ROM:00001042 ; -----
ROM:00001044          DCB 0x32 ; 2
ROM:00001045          DCB 0xFB
ROM:00001046          DCB 0x36 ; 6
ROM:00001047          DCB 0x76 ; v
ROM:00001048          DCB 0x2C ; ,
ROM:00001049          DCB 0xC
ROM:0000104A          DCB 0x9E
ROM:0000104B          DCB 0
ROM:0000104C          DCB 0xD3
ROM:0000104D          DCB 0x3E ; >
ROM:0000104E          DCB 0xAC
ROM:0000104F          DCB 0x6B ; k
ROM:00001050          DCB 0xDC
ROM:00001051          DCB 0x7A ; z
ROM:00001052          DCB 0x8B
ROM:00001053          DCB 0xF8
ROM:00001054          DCB 1
ROM:00001055          DCB 0x34 ; 4
ROM:00001056          DCB 0x1E

```

4-1-18 OS Hardening

보안 대책	OS Hardening
테스트케이스 명	기본 보안 설정 여부 점검
UN R155 Annex5	7.2/17.1
Pre-Condition	Linux Shell 접근
필요 도구	-
테스트 과정	

1) KISA 주요정보통신기반 가이드라인을 기반으로 테스트 수행

```
[!] Setting the Kiosk mode.
[Kiosk] Set auto logon for current account
[=] The system can apply Autologon about kiosk account(ABC)
True
[Kiosk] Set program for kiosk mode
[!] Setting the KISA Guideline
[KISA-Account Manage] PC-15 : Disable autologon in recovery console.
[=] The registry SecurityLevel sets as 0.

True
[KISA-Service Manage] PC-03 : Remove shared directory.
[=] The registry AutoShareServer sets as 0.

True
[KISA-Service Manage] PC-04 : Disable the useless service.
[!] The list of needless services is referenced by KISA guideline.
```

05 맺음말

한국인터넷진흥원

자동차 산업은 소프트웨어 정의 차량(SDV), 자율주행 기술, 커넥티비티 확산 등으로 빠르게 변화하고 있으며, 이에 따라 사이버보안 위협도 점차 복잡하고 정교해지고 있다. 국제적으로는 UN Regulation No.155, No.156과 ISO/SAE 21434가 시행되고 있으며, 국내 역시 자동차관리법 개정을 통해 사이버보안 관리체계(CSMS)와 소프트웨어 업데이트 관리체계(SUMS) 준수를 요구하고 있다. 이에 따라 제조사와 부품 공급사는 개발 초기부터 양산 이후까지 전 주기에 걸쳐 보안성을 검증해야 하는 상황이다.

본 가이드라인은 이러한 규제와 표준의 요구사항을 충족하기 위해 수행될 수 있는 사이버보안 테스트 절차와 방법론을 제시한다. 퍼징(Fuzzing), 취약점 스캐닝(Vulnerability Scanning), 침투 테스트(Penetration Testing)와 같은 기법은 상호 보완적으로 적용되며, 제어기에 구현된 보안 대책이 실제 환경에서 기대한 대로 동작하는지를 확인하는 수단이다. 또한 TARA(Threat Analysis and Risk Assessment)를 통해 식별된 자산과 위협 수준을 기반으로 사이버보안 등급이 결정되며, 이에 따라 차등적으로 적용된 보안 대책을 검증하는 과정이 필요하다.

다만 사이버보안 테스트는 전문적인 역량과 최신 위협 동향에 대한 지속적인 학습, 다양한 장비 운용 능력이 요구된다. 따라서 모든 검증을 내부 인력만으로 수행하는 데에는 한계가 있을 수 있다. 이러한 점에서 필요에 따라 전문 기관과 협력하여 정밀한 테스트를 수행하거나 외부 보안 평가를 병행하는 것도 바람직한 방법이다. 이를 통해 보다 객관적이고 신뢰성 있는 검증 결과를 확보할 수 있으며, 결과적으로 규제 대응뿐 아니라 실제 차량의 안전성과 신뢰성을 한층 강화할 수 있다.

주관 기관 : 한국인터넷진흥원(KISA)

공동 참여 기관 : 자동차안전연구원(KATRI), 자동차융합기술원(JIAT)

사업 수행사 : (주)페스카로

[부록] 정보보호 관리체계(ISMS)와 사이버보안 관리체계(CSMS)

한국인터넷진흥원

부록-1 정보보호 관리체계(ISMS)와 사이버보안 관리체계(CSMS) 배경

디지털 전환의 가속화와 산업 융합의 심화는 전 세계 기업들에게 새로운 보안 위협을 가져오고 있습니다. 과거에는 정보통신 서비스 기업이나 금융기관처럼 데이터와 네트워크를 직접 다루는 조직이 주된 보안 규제의 대상이었지만, 오늘날에는 제조업, 에너지, 모빌리티 산업까지 사이버보안이 조직의 핵심 경쟁력과 직결되고 있습니다. 특히 자동차 산업은 전통적인 기계공학 기반 산업에서 소프트웨어 중심 산업으로 전환하면서, 그 어느 때보다 높은 수준의 보안 관리체계가 요구되고 있습니다.

국내에서는 한국인터넷진흥원(KISA)이 운영하는 ISMS(Information Security Management System, 정보보호 관리체계 인증) 제도가 이러한 보안 관리체계의 대표적 예라 할 수 있다. ISMS는 일정 규모 이상의 정보통신서비스 제공자나 기업을 대상으로, 조직이 보안 정책과 위험관리 체계를 수립하고 이를 운영·개선하고 있는지를 평가·인증하는 제도입니다. 따라서 ISMS는 국내 ICT 기업에게 보안 거버넌스를 마련하고 운영하도록 하는 기본적이고 필수적인 제도적 장치라고 할 수 있습니다.

한편, 자동차 산업은 커넥티드카, OTA(Over-the-Air) 소프트웨어 업데이트, V2X 통신, SDV(Software Defined Vehicle) 등 새로운 기술로 인해 IT 서비스 못지않게 사이버 공격에 노출되고 있습니다. 자동차가 더 이상 단순한 기계 장치가 아닌, 수십, 수백 개의 ECU와 수천만 줄의 코드로 구성된 복잡한 소프트웨어 시스템이 되었기 때문이다. 이러한 변화는 단순한 정보 유출 사고를 넘어, 차량 제어권 탈취, 원격 해킹을 통한 안전사고 등 인명과 직결된 사이버보안 리스크로 이어질 수 있습니다.

이런 맥락에서 국제적으로 제정된 것이 바로 ISO/SAE 21434인 자동차 사이버보안 국제표준이며, 이 표준을 규제 기반으로 적용한 것이 UNECE R155 차량 사이버보안 규제이다. UNECE R155는 유럽 시장에 차량을 판매하는 OEM(완성차 제조사)에게 CSMS(Cyber-Security Management System, 사이버보안 관리체계)를 구축하도록 의무화하고 있으며, 2022년 7월 이후 신규 형식승인을 받는 차량부터 적용되었으며, 2024년 7월 이후에는 모든 신규 판매 차량에 확대 적용되었습니다. 즉, 유럽 시장 진출 시 OEM은 CSMS 준수는 필수 인증에 해당됩니다.

중요한 점은 현 작성 시점인 25년 기준 CSMS의 법적 의무 주체는 OEM에 해당되며, Tier-1이나 Tier-2와 같은 부품사는 직접적으로 CSMS를 인증받거나 규제 당국의 심사를 받을 의무가 없습니다. 그러나 OEM이 차량 형식승인을 위해서는 공급망 전반에서 CSMS 요구사항을 충족해야 하기 때문에, 공급사 역시 OEM의 요구에 따라 사실상 CSMS 수준의 체계를 갖추고 증적을 제공해야 합니다. Tier 업체는 규제 대상은 아니지만 OEM과 협력하기 위해서 ISO/SAE21434의 조직 및 프로세스, 정책 등 내재화를 진행중입니다.

ISMS와 CSMS는 등장 배경과 적용 범위에 차이는 있지만, 공통적으로 "조직적이고 지속적인 사이버보안 관리 체계"를 요구하는 점에서 공통점을 지니고 있습니다. ISMS가 국내 ICT 및 일반 기업의 정보보호 관리 수준을 높이며, CSMS는 자동차 산업에서 OEM을 중심으로 한 공급망 전반의 사이버보안 수준 높이는 제도입니다.

ISMS와 CSMS는 제정 목적과 적용 범위가 다른 제도이지만, 공통적으로 조직적·체계적 보안 관리의 중요성을 전제하고 있다. 특히 차량이 소프트웨어와 네트워크 기반으로 진화하면서, 과거 정보통신 서비스에서 요구되던 보안 관리의 사고방식이 차량 사이버보안 영역에서도 요구되며, 관리체계 기반의 보안을 자동차 산업에도 확산되고 있습니다.

부록-2 ISMS 소개

정보보호 관리체계(ISMS, Information Security Management System)는 조직이 보유한 정보자산의 기밀성, 무결성, 가용성을 보호하기 위해 마련된 관리체계 인증 제도입니다. 이는 단편적인 보안 기술 도입을 넘어, 조직 차원에서 수립 - 운영 - 점검 - 개선의 순환 구조를 주기적으로 수행하도록 제시함으로써, 정보보호를 경영 시스템의 일부로 정착시키는 것을 목적입니다.

대한민국에서는 한국인터넷진흥원(KISA)이 ISMS 인증제도를 관리하고 있으며, 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」 및 관련 고시에 따라 일정 규모 이상의 정보통신서비스 제공자와 기업은 법적으로 ISMS 인증을 반드시 획득해야 합니다. 이는 기업이 보유·처리하는 개인정보와 중요 정보자산의 가치가 높아짐에 따라, 보안 침해 사고 발생 시 사회적·경제적 파급효과가 크다는 점을 반영한 조치이다. 따라서 ISMS는 자율적 선택이 아니라 법률상 강제되는 최소한의 보안 관리체계로 자리 잡고 있습니다.

아울러, ISMS에 개인정보보호 관리체계(PIMS) 요건을 통합한 ISMS-P 제도가 운영중이며, ISMS-P는 정보보호 관리체계(ISMS)와 개인정보보호 관리체계(PIMS)를 아우르는 확장형 인증으로, 개인정보 처리 업무가 중요한 조직을 대상으로 보다 강화된 관리·보호 조치를 요구합니다.

ISMS의 주요 구성 요소는 다음과 같다.

- 가. 관리체계 수립 및 운영: 정보보호 정책의 수립, 위험관리 절차의 운영, 조직 구성 및 역할 책임 정의, 경영진의 참여와 의사결정 구조 마련 등 거버넌스 확립
- 나. 보호대책 요구사항: 인적 보안, 물리적 보안, 기술적 보안(접근통제, 암호화, 시스템 및 네트워크 보안 등)을 포함하는 실행적 보안 항목
- 다. 인증 심사 및 유지관리: ISMS 인증은 최초 심사를 통해 획득하며 3년간 유효하다. 또한 매년 사후 심사를 통해 관리 수준을 점검 받아야 하며, 이를 통해 형식적인 인증이 아닌 지속적인 개선과 운영이 가능하도록 제도화.

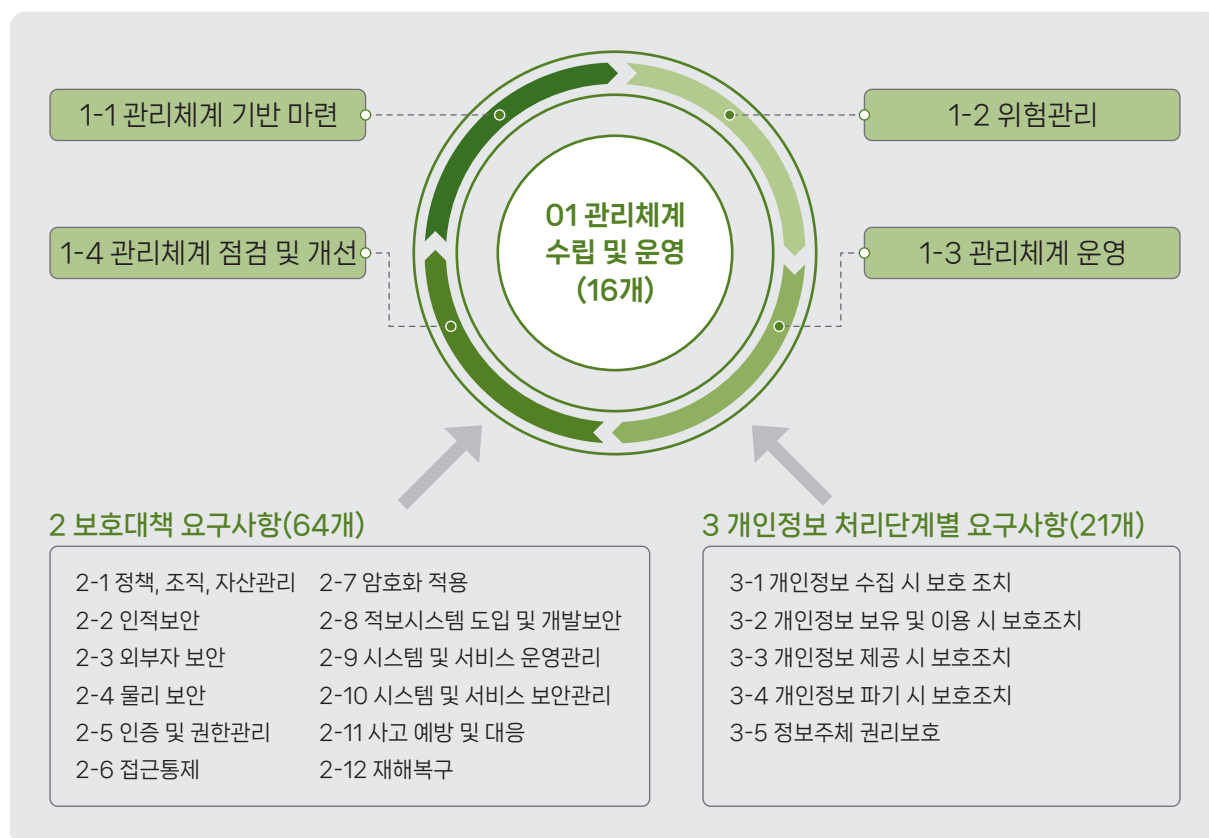


그림 12 ISMS 심사 내 주요 요구사항

부록-3 ISO/SAE 21434 소개

사이버보안 관리체계(CSMS, Cybersecurity Management System)는 자동차 산업의 고도화된 E/E(전기·전자) 아키텍처와 소프트웨어 의존도가 높아짐에 따라 증가하는 사이버 위협에 대응하기 위해 마련된 관리체계입니다. 이는 국제 표준 ISO/SAE 21434:2021을 기반으로, 차량 및 전장시스템 개발 전 과정에서 보안을 체계적으로 고려할 것을 요구하고 있습니다.

적용 대상 및 의무성

CSMS는 UN Regulation No. 155(UN R155, 차량 사이버보안 규정)을 통해 OEM(자동차 제조사)에게 법적으로 의무화되어 있다. 따라서 유럽연합(EU) 및 UN R155 채택국가에서 차량을 판매하려는 OEM은 반드시 CSMS를 수립하고 유지해야 하며, 형식승인 과정에서 이를 증명해야 합니다.

Tier-1·Tier-2와 같은 협력사에는 직접적인 규제 대상은 아니지만, OEM의 공급망 보안 요구에 의해 CSMS 수준의 관리체계 대응 마련이 필요합니다. 이는 CSMS가 OEM과 협력하는 자동차 산업 전반에서 함께 참여해야 되는 요건으로 전개되고 있습니다

주요 구성 요소 (Clause 4-15)

ISO/SAE 21434에 근거한 CSMS는 차량의 전체 생명주기(lifecycle)를 대상으로 하며, 구체적인 구성은 다음과 같습니다.

- 가. 일반적 고려사항 (Clause 4): 용어 정의, 적용 범위 등 기본 원칙
- 나. 조직의 사이버보안 관리 (Clause 5): 사이버보안 거버넌스, 문화, 정보 공유, 관련 시스템, 도구 및 자원, 내부 심사 등 조직 차원의 관리
- 다. 프로세스 통합 사이버보안 관리 (Clause 6): 계획, 테일러링, 재사용, 사이버보안 활동 평가, 규격·표준 준수, 사이버보안 케이스 등 프로젝트 관리
- 라. 분산 사이버보안 활동 (Clause 7): 및 외부 협력자와의 연계, 계약 조건, 책임 분담
- 마. 지속적 사이버보안 활동 (Clause 8): 이벤트 평가, 취약점 분석·관리 등 지속적 운영 활동
- 바. 개념 단계 (Clause 9): 아이템 정의, 사이버보안 목표 설정, 보안 개념 도출
- 사. 제품 개발 단계 (Clause 10-11): 설계, 구현, 통합 및 검증, 사이버보안 타당성 확인
- 아. 개발 이후 단계 (Clause 12-14): 운영 및 유지보수, 사고 대응, 업데이트, 지원 종료 및 폐기 단계 관리
- 자. 위협 분석 및 위험 평가 (Clause 15): 자산 식별, 위협 시나리오, 공격 경로 및 영향 분석, 위험 평가와 분류

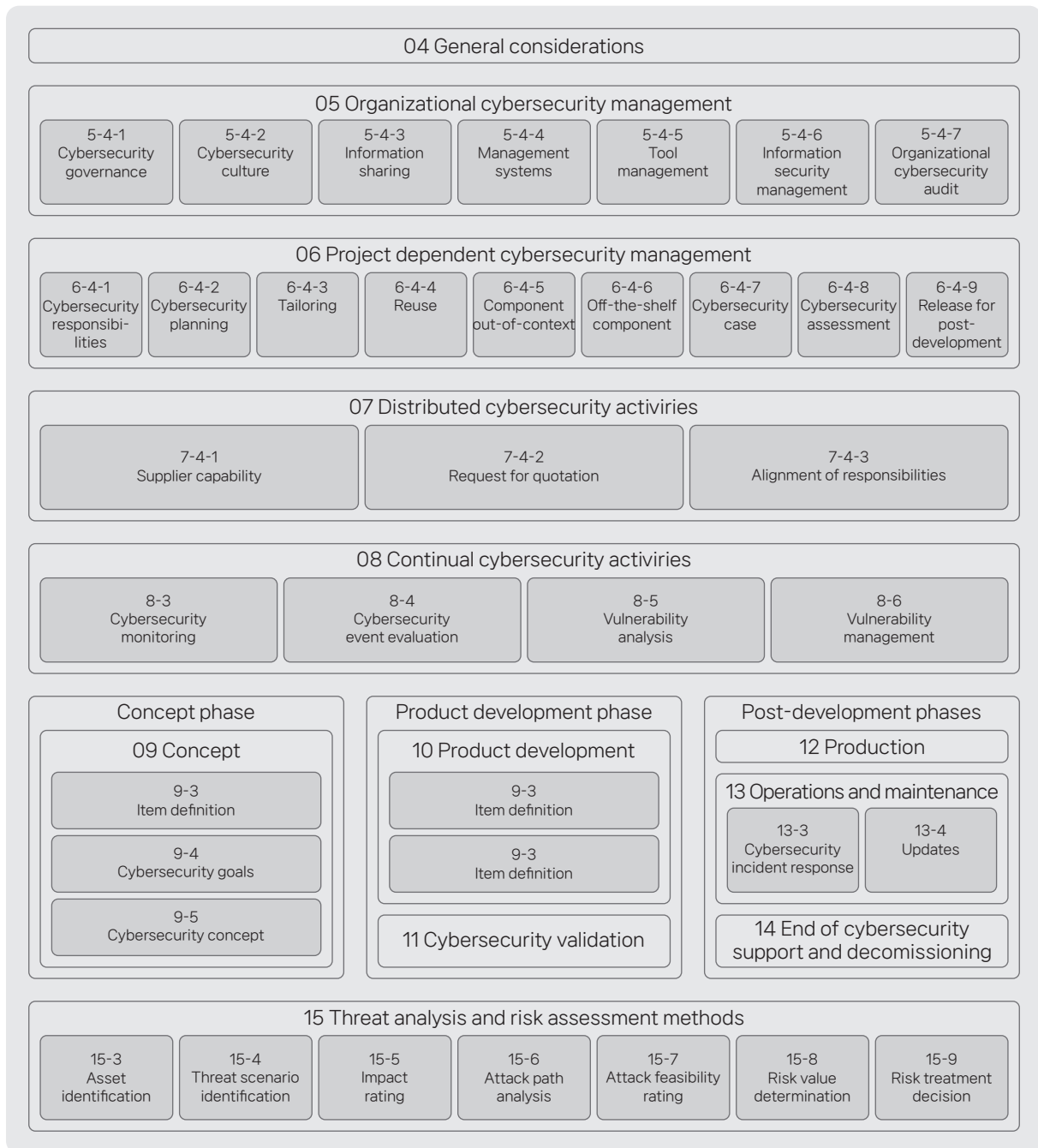


그림 13 ISO/SAE 21434 개요

운영 및 유지

CSMS는 일회성 인증이 아니라 지속적으로 운영·갱신해야 하는 관리체계이다. UN R155는 OEM이 차량을 판매 하는 동안 CSMS를 유지하고, 정기적으로 평가받을 것을 정의되어 있습니다. CSMS는 단순히 인증 취득에 그치지 않고, 차량 생애주기 전반에서 지속 가능한 보안 운영을 실현하는 제도적 활용됩니다.

부록 4 정보보호 관리체계(ISMS)와 사이버보안 관리체계(CSMS) 비교

정보보호 관리체계(ISMS)는 조직의 정보자산 전반에 대한 보호 체계를 확립하고 운영하기 위한 제도로, 국내에서는 일정 규모 이상의 정보통신서비스 제공자와 기업에게 적용됩니다. 반면, ISO/SAE 21434 기반의 사이버보안 관리체계(CSMS)는 차량의 생애주기 전반에 걸쳐 사이버보안을 관리하는 국제 표준으로, 주로 완성차 제조사(OEM)가 UNECE R155 규제 대응을 위해 반드시 갖추어야 하며, 협력사(Tier)들도 그들의 사이버보안 요구 사항에 부합하기 위해 일부 대응이 필요하다. 두 관리체계는 적용 대상과 범위는 다르지만, 모두 조직 차원의 보안 거버넌스 확립, 리스크 기반 접근, 지속적 개선이라는 방향성은 동일합니다.

본 비교표는 정보보호 관리체계(ISMS)와 사이버보안 관리체계(CSMS)의 주요 항목을 정리한 것으로, ISMS 인증기준 세부점검항목 대상으로 ISO/SAE 21434 공통 및 유사 내용은 아래와 관련성이 있습니다.

부록 5 ISMS 기반 ISO/SAE 21434 요구사항 비교

ISMS 절	판단 기준	항목 번호	항목명	ISO/SAE 21434 상세 조항(번호+절명)	공통점·유사점 (요약)
제1절	1-1 관리체계 기반 마련	1-1-1	경영진의 참여	5.4.1 Cybersecurity governance; 5.4.2 Cybersecurity culture	경영진의 거버넌스/문화 주도와 정책 승인 요구
제1절	1-1 관리체계 기반 마련	1-1-2	최고책임자의 지정	5.4.1 Cybersecurity governance; 6.4.1 Cybersecurity responsibilities	보안 최고책임자 지정 및 프로젝트별 책임 할당 요구
제1절	1-1 관리체계 기반 마련	1-1-3	조직 구성	5.4.1 Cybersecurity governance; 6.4.1 Cybersecurity responsibilities	조직 내 역할·책임 정의 및 운영 요구
제1절	1-1 관리체계 기반 마련	1-1-4	범위 설정	6.4.2 Cybersecurity planning; 5.4.4 Management systems	적용 범위·경계 정의와 보안 계획 수립
제1절	1-1 관리체계 기반 마련	1-1-5	정책 수립	5.4.1 Cybersecurity governance; 5.4.2 Cybersecurity culture; 5.4.3 Information sharing	정책/규칙 제정과 전사 공유·정착.
제1절	1-1 관리체계 기반 마련	1-1-6	자원 할당	5.4.4 Management systems; 5.4.5 Tool management	인력·예산·도구 등 자원 배정 및 도구 관리
제1절	1-2 위험 관리	1-2-1	정보자산 식별	9.3 Item definition; 15.3 Asset identification	보호대상(아이템/자산) 식별 요구
제1절	1-2 위험 관리	1-2-2	현황 및 흐름분석	9.3 Item definition; 15.3 Asset identification	경계/인터페이스·흐름 파악에 기반한 리스크 접근

ISMS 절	판단 기준	항목 번호	항목명	ISO/SAE 21434 상세 조항(번호+절명)	공통점·유사점 (요약)
제1절	1-2 위험 관리	1-2-3	위험 평가	15.4 Threat scenario identification; 15.5 Impact rating; 15.7 Attack feasibility rating; 15.8 Risk value determination	위험·영향·공격 용이도 평가를 통한 위험값 산정
제1절	1-2 위험 관리	1-2-4	보호대책 선정	9.4 Cybersecurity goals; 9.5 Cybersecurity concept; 15.9 Risk treatment decision	목표/개념 수립과 위험처리 결정 절차
제1절	1-3 관리체계 운영	1-3-1	보호대책 구현	10.4.1 Design; 10.4.2 Integration and verification	설계·통합·검증 등 구현 활동
제1절	1-3 관리체계 기반 마련	1-3-2	보호대책 공유	5.4.3 Information sharing; 7.4.3 Alignment of responsibilities	조직·공급망 간 정보 공유·책임 정렬
제1절	1-3 관리체계 기반 마련	1-3-3	운영현황 관리	8.3 Cybersecurity monitoring; 8.4 Cybersecurity event evaluation; 8.5 Vulnerability analysis; 8.6 Vulnerability management	모니터링·이벤트 평가·취약점 관리
제1절	1-4 관리체계 기반 마련	1-4-1	법적 요구사항 준수 검토	5.4.7 Organizational cybersecurity audit; 6.4.8 Cybersecurity assessment	내부 감사/평가를 통한 준수 확인
제1절	1-4 관리체계 기반 마련	1-4-2	관리체계 점검	5.4.7 Organizational cybersecurity audit; 8.3 Cybersecurity monitoring	상시 점검·감사의 체계
제1절	1-4 관리체계 기반 마련	1-4-3	관리체계 개선	8.4 Cybersecurity event evaluation; 8.6 Vulnerability management	이벤트/취약점 결과 기반의 개선 조치





ISO/SAE 21434 기반 자동차 사이버보안 테스트 및 검증 매뉴얼

자동차 부품 제조사를 위한 TARA 지침서 Vol.2

인 쇄 2025년 12월 31일

발 행 2025년 12월 31일

발행처 한국인터넷진흥원

주 소 전라남도 나주시 진흥길 9 한국인터넷진흥원

Tel. (061)820-1473 / www.kisa.or.kr

